



**ΠΑΝΕΠΙΣΤΗΜΙΟ
ΜΑΚΕΔΟΝΙΑΣ**

ΕΦΑΡΜΟΣΜΕΝΗ ΠΛΗΡΟΦΟΡΙΚΗ

05/06/2021, ΘΕΣΣΑΛΟΝΙΚΗ

**ΤΜΗΜΑ ΕΦΑΡΜΟΣΜΕΝΗΣ ΠΛΗΡΟΦΟΡΙΚΗΣ
ΠΤΥΧΙΑΚΗ ΕΡΓΑΣΙΑ**

**Αξιολόγηση πηγών πληροφόρησης για κυβερνοαπειλές και
ταξινόμηση περιεχομένου**



ΕΥΣΤΡΑΤΙΟΣ ΛΟΝΤΖΕΤΙΔΗΣ dai18006

Επιβλέπων καθηγητής: Ιωάννης Μαυρίδης

ΕΥΧΑΡΙΣΤΙΕΣ

Στο σημείο αυτό αισθάνομαι την ανάγκη να εκφράσω τις ειλικρινείς και θερμές ευχαριστίες μου σε όσους συνέβαλαν στην ολοκλήρωση αυτής της προσπάθειας:

Και πρώτα απ' όλα στον επιβλέποντα καθηγητή της διπλωματικής μου εργασίας, κύριο Ιωάννη Μαυρίδη, την συνεχή καθοδήγηση, τις ουσιώδεις συμβουλές και την ενθάρρυνση για το καλύτερο δυνατό αποτέλεσμα της εργασίας.

Επίσης θα ήθελα να ευχαριστήσω θερμά τους κυρίους Αθανάσιο Δημητριάδη και τον Χρήστο Πρασσά, υποψήφιους διδάκτορες του τμήματος Εφαρμοσμένης Πληροφορικής του Πανεπιστημίου Μακεδονίας, οι οποίοι με υποστήριξαν σε όλη την διάρκεια της έρευνας και της συγγραφής της εργασίας, μου έδωσαν πολύτιμες συμβουλές για να συνεχίσω την έρευνά μου και ήταν πάντα διαθέσιμοι σε οποιαδήποτε απορία μου, πρόθυμοι να μου εξηγήσουν αναλυτικά.

Τέλος, θα επιθυμούσα να ευχαριστήσω όλους εκείνους που στάθηκαν δίπλα μου και με στήριξαν σε όλα τα άγχη και τους αγώνες μου αυτά τα 4 έτη σπουδών: την οικογένειά μου και τους φίλους μου.

ΠΕΡΙΛΗΨΗ

Σκοπός αυτής της εργασίας είναι η πραγματοποίηση ανάλυσης και αξιολόγησης των πηγών που προσφέρουν υπηρεσίες διαμοιρασμού πληροφοριών για κυβερνοαπειλές (cyber threat information). Αρχικά, παρουσιάζεται το θεωρητικό υπόβαθρο και παρέχονται οι βασικές έννοιες. Στη συνέχεια, παρουσιάζονται συνοπτικά, ο διαμοιρασμός πληροφοριών για κυβερνοαπειλές και το πρότυπο STIX (structured threat information expression), το οποίο χρησιμοποιείται για την αναπαράσταση των διάφορων απειλών που υπάρχουν στον κυβερνοχώρο.

Βασικό υλικό της εργασίας είναι ο εντοπισμός των πηγών που ελεύθερα προσφέρουν τέτοιες πληροφορίες, η σύνδεση με αυτές και η άντληση του περιεχομένου τους. Το εν λόγω περιεχόμενο αποθηκεύτηκε μια τοπική βάση δεδομένων. Στην περίπτωση που κάποιες πηγές δεν προσέφεραν πληροφορίες στο πρότυπο STIX, αναπτύχθηκαν κατάλληλες διεπαφές για τη μετατροπή τους από την επιμέρους μορφή δεδομένων στο συγκεκριμένο πρότυπο. Οι πηγές που αξιοποιούνται και αναλύονται είναι οι MISP, MITRE, BLUELIV, PULSEDIVE, OTX-ALIENVault, URLhaus, ANOMALI και MRLOOQUER. Αυτές ταξινομούνται στη βάση του περιεχομένου τους που σχετίζεται με βασικές κατηγορίες κυβερνοαπειλών που υπάρχουν στο πρότυπο του STIX2, για τις οποίες παρέχουν CTI, αλλά και με φάσεις του μοντέλου επιθέσεων (kill chain). Για τη ποιοτική αξιολόγηση των πηγών, καθορίστηκαν τέσσερα (4) κριτήρια (φρεσκάδα, πληρότητα, πρωτοτυπία, επίπτωση), βάση βιβλιογραφίας, ενώ λαμβάνονται επιπλέον υπόψη οι οπτικές της παροχής πληροφοριών για τα απαραίτητα βήματα προς τον περιορισμό των απειλών στον κυβερνοχώρο (course of action), καθώς και της προσφοράς αναφορών σχετικά με γνωστές ευπάθειες, γνωστά μοτίβα επίθεσης και γνωστές πλατφόρμες.

Από τα αποτελέσματα της ταξινόμησης του περιεχομένου, φαίνεται πως οι πιο γνωστές πηγές περιέχουν περισσότερες διαφορετικές κατηγορίες αντικειμένων STIX2, ενώ οι λιγότερο γνωστές συνήθως περιέχουν μία με τρεις κατηγορίες το πολύ. Τέλος, οι πηγές οι οποίες περιέχουν στάδια αλυσίδας επιθέσεων, είναι οι γνωστότερες MISP και MITRE. Όσον αφορά την φάση της αξιολόγησης των πηγών, τα αποτελέσματα που προκύπτουν είναι πως ως προς το ποιοτικό κριτήριο της φρεσκάδας, οι λιγότερο γνωστές πηγές προσφέρουν πιο επίκαιρα δεδομένα από τις πιο φημισμένες. Ως προς το κριτήριο της πληρότητας συμβαίνει το αντίθετο, οι πιο γνωστές πηγές προσφέρουν περισσότερη και πιο πλήρη πληροφορία από τις λιγότερο γνωστές πηγές. Επιπλέον, η μόνη πηγή που διαθέτει πληροφορίες για τα απαραίτητα βήματα προς τον περιορισμό των απειλών είναι η πηγή MITRE. Τέλος, σχετικά με την ύπαρξη αναφορών για γνωστές ευπάθειες, γνωστά μοτίβα επίθεσης και γνωστές ευπαθείς πλατφόρμες, τα αποτελέσματα δείχνουν πως στις περισσότερες πηγές υπάρχουν τέτοιες αναφορές.

Λέξεις κλειδιά: CTI, πληροφόρηση για κυβερνοαπειλές, διαμοιρασμός γνώσης, STIX

ΠΙΝΑΚΑΣ ΠΕΡΙΕΧΟΜΕΝΩΝ

ΠΙΝΑΚΑΣ ΠΕΡΙΕΧΟΜΕΝΩΝ	4
ΚΑΤΑΛΟΓΟΣ ΠΙΝΑΚΩΝ	5
ΚΑΤΑΛΟΓΟΣ ΕΙΚΟΝΩΝ.....	5
ΚΑΤΑΛΟΓΟΣ ΓΡΑΦΗΜΑΤΩΝ.....	5
1. ΕΙΣΑΓΩΓΗ.....	7
2. ΘΕΩΡΗΤΙΚΟ ΥΠΟΒΑΘΡΟ.....	8
2.1. ΒΑΣΙΚΕΣ ΕΝΝΟΙΕΣ	8
2.2. CYBER THREAT INFORMATION	10
2.3. STRUCTURED THREAT INFORMATION EXPRESSION	11
3. ΠΟΙΟΤΙΚΑ ΚΡΙΤΗΡΙΑ ΓΙΑ ΤΗΝ ΑΞΙΟΛΟΓΗΣΗ ΚΥΒΕΡΝΟΑΠΕΙΛΩΝ.....	14
3.1. ΦΡΕΣΚΑΔΑ	14
3.2. ΠΛΗΡΟΤΗΤΑ.....	15
3.3. ΠΡΩΤΟΤΥΠΙΑ	15
3.4. ΕΠΪΠΤΩΣΗ.....	16
4. ΚΑΤΑΓΡΑΦΗ ΠΗΓΩΝ CTI	17
4.1. ΕΠΙΛΟΓΗ ΣΥΣΤΗΜΑΤΟΣ ΔΙΑΧΕΙΡΙΣΗΣ ΒΑΣΗΣ ΔΕΔΟΜΕΝΩΝ	17
4.2. ΠΗΓΕΣ CTI	18
5. ΔΙΕΠΑΦΕΣ ΜΕΤΑΤΡΟΠΗΣ.....	20
5.1. ΜΕΤΑΤΡΟΠΗ URLHAUS	20
5.2. ΜΕΤΑΤΡΟΠΗ BLUELIV	21
5.3. ΜΕΤΑΤΡΟΠΗ PULSEDIVE	22
5.4. ΜΕΤΑΤΡΟΠΗ MRLOOQUER	23
5.5. ΜΕΤΑΤΡΟΠΗ ΟΤΧ	24
6. ΤΑΞΙΝΟΜΗΣΗ ΑΝΑΚΤΗΘΕΝΤΟΣ ΠΕΡΙΕΧΟΜΕΝΟΥ.....	25
6.1. ΤΑΞΙΝΟΜΗΣΗ ΠΕΡΙΕΧΟΜΕΝΟΥ ΜΕ ΒΑΣΗ STIX2 SDO	25
6.2. ΤΑΞΙΝΟΜΗΣΗ ΠΕΡΙΕΧΟΜΕΝΟΥ ΜΕ ΒΑΣΗ ΤΑ ΣΤΑΔΙΑ KILL CHAIN	29
7. ΠΟΙΟΤΙΚΗ ΑΞΙΟΛΟΓΗΣΗ ΤΩΝ ΠΗΓΩΝ CTI.....	30
7.1. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΗ ΦΡΕΣΚΑΔΑ	32
7.2. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΗ ΠΛΗΡΟΤΗΤΑ	33
7.3. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΑ COA	38
7.4. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΑ CVE, CPE, CAPEC.....	39
8. ΕΠΙΛΟΓΟΣ	41
9. ΒΙΒΛΙΟΓΡΑΦΙΑ	42

ΚΑΤΑΛΟΓΟΣ ΠΙΝΑΚΩΝ

ΠΙΝΑΚΑΣ
<u>Πίνακας I: Σύνδεση με CTI πηγές.</u>
<u>Πίνακας II: Είδη αντικειμένων STIX2 που περιέχονται σε κάθε πηγή.</u>
<u>Πίνακας III: Ανάλυση πηγών με βάση τα ποιοτικά κριτήρια φρεσκάδας και πληρότητας.</u>
<u>Πίνακας IV: Ανάλυση πηγών με βάση CoA και CVE,CPE και CAPEC.</u>

ΚΑΤΑΛΟΓΟΣ ΕΙΚΟΝΩΝ

ΕΙΚΟΝΑ
<u>Εικόνα 1: Μορφή και παράδειγμα ενός CPE.</u>
<u>Εικόνα 2: Martin Lockheed's Cyber Kill Chain.</u>
<u>Εικόνα 3: Παράδειγμα σχέσης μεταξύ δύο SDOs.</u>
<u>Εικόνα 4: Παράδειγμα σχέσης μεταξύ δύο SDOs με ένα SRO σε STIX2 format.</u>
<u>Εικόνα 5: Μετατροπή των CTIPs της URLHAUS σε STIX2.</u>
<u>Εικόνα 6: Μετατροπή των CTIPs της BLUELIV σε STIX2</u>
<u>Εικόνα 7: Μετατροπή των CTIPs της PULSEDIVE σε STIX2</u>
<u>Εικόνα 8: Μετατροπή των CTIPs της MRLOOQUER σε STIX2</u>
<u>Εικόνα 9: Μετατροπή των CTIPs της OTX σε STIX2</u>

ΚΑΤΑΛΟΓΟΣ ΓΡΑΦΗΜΑΤΩΝ

ΓΡΑΦΗΜΑ
<u>Γράφημα 1: SDOs που προσφέρει η ANOMALI.</u>
<u>Γράφημα 2: SDOs που προσφέρει η MISP.</u>
<u>Γράφημα 3: SDOs που προσφέρει η MITRE.</u>

<u>Γράφημα 4: SDOs που προσφέρει η OTX.</u>
<u>Γράφημα 5: SDOs που προσφέρει η PULSEDIVE.</u>
<u>Γράφημα 6: SDOs που προσφέρει η MRLOOQUER.</u>
<u>Γράφημα 7: SDOs που προσφέρει η URLHAUS.</u>
<u>Γράφημα 8: SDOs που προσφέρει η BLUELIV.</u>
<u>Γράφημα 9: CTIPs της MISP ανά KC στάδιο.</u>
<u>Γράφημα 10: Φρεσκάδα για κάθε πηγή.</u>
<u>Γράφημα 11: Πληρότητα των πηγών για Malware SDO.</u>
<u>Γράφημα 12: Πληρότητα των πηγών για Indicator SDO.</u>
<u>Γράφημα 13: Πληρότητα των πηγών για Identity SDO.</u>
<u>Γράφημα 14: Πληρότητα των πηγών για Attack Pattern SDO.</u>
<u>Γράφημα 15: Πληρότητα των πηγών για Course of Action SDO.</u>
<u>Γράφημα 16: Πληρότητα των πηγών για Report SDO.</u>
<u>Γράφημα 17: Πληρότητα των πηγών για Infrastructure SDO.</u>
<u>Γράφημα 18: Πληρότητα των πηγών για Observed Data SDO.</u>
<u>Γράφημα 19: Πληρότητα των πηγών για Vulnerability SDO.</u>
<u>Γράφημα 20: Πληρότητα των πηγών για Tool SDO.</u>
<u>Γράφημα 21: Πληρότητα των πηγών για Intrusion Set SDO.</u>
<u>Γράφημα 22: CoA στα CTIPs της MITRE.</u>
<u>Γράφημα 23: Παροχή αναφορών για CVE στις πηγές.</u>
<u>Γράφημα 24: Παροχή αναφορών για CAPEC στις πηγές.</u>

1. ΕΙΣΑΓΩΓΗ

Η πρόοδος της τεχνολογίας τα τελευταία χρόνια έχει προσφέρει πολλαπλά οφέλη στην λειτουργία και παραγωγικότητα των επιχειρήσεων. Στην εποχή της πανδημίας του COVID-19, οι περισσότερες εταιρείες λειτουργούν με τηλεργασία προσφέροντας ευελιξία στους υπαλλήλους τους με αξιοποίηση των τεχνολογιών με βάση το διαδίκτυο. Η χρήση αυτών των τεχνολογιών όμως, προσφέρει και καινούριες δυνατότητες στους επιτιθέμενους, οι οποίοι έχουν στο στόχαστρο τους υπαλλήλους οργανισμών που δουλεύουν “από το σπίτι”. Οι επιτιθέμενοι βασίζονται στην απειρία των χρηστών σε θέματα ασφαλείας διαδικτύου, αλλά και σε ήπιες ή ανύπαρκτες πολιτικές ασφαλείας από πλευράς των εταιρειών. Έτσι λοιπόν, με τις πρωτόγνωρες συνθήκες εργασίας, οι περισσότεροι βρίσκονται ευάλωτοι σε διάφορους τύπους επιθέσεων, όπως ηλεκτρονικό ψάρεμα (phishing), κοινωνική μηχανική (social engineering) και επιθέσεις κακόβουλων λογισμικών (malware), με πιθανές συνέπειες την υποκλοπή ή καταστροφή δεδομένων και την καταρράκωση της φήμης της εταιρείας τους.

Η διαχείριση και ο μετριασμός των επιθέσεων, έχει γίνει πλέον μια αυξανόμενη πρόκληση. Οι λύσεις για την ασφάλεια στον κυβερνοχώρο προσπαθούν κυρίως να λάβουν αμυντική στάση και να χτίσουν ένα τείχος γύρω από τις σχετικές τεχνολογίες σε μια προσπάθεια να τις προστατέψουν. Ωστόσο, οι δράστες καταφέρνουν πάντα να βρουν τρόπους να διεισδύσουν σε δίκτυα και συστήματα. Ο κύριος τρόπος της αμυντικής δράσης είναι η εφαρμογή των περιοριστικών μέτρων στα συστήματα πριν (προληπτικά), κατά ή μετέπειτα από μια κυβερνοεπίθεση, από τα στελέχη κυβερνοασφάλειας της κάθε επιχείρησης. Οι ομάδες κυβερνοασφάλειας δρουν μέσα στο οικοσύστημα τους, υλοποιούν αμυντικές τεχνικές και τρόπους περιορισμού των συχνότερων επιθέσεων.

Μια τεχνολογία η οποία θα επέτρεπε το διαμοιρασμό των πληροφοριών για τις κυβερνοαπειλές θα μπορούσε να χτίσει ισχυρές άμυνες ενάντια στους επιτιθέμενους. Με αυτόν τον τρόπο, όλοι οι οργανισμοί, θα ήταν σε θέση να μοιράζονται τις επιθέσεις που δέχτηκαν με σκοπό την επίτευξη κυβερνοασφαλείας συνεργατικά. Έτσι ο κάθε οργανισμός θα μπορούσε να μοιραστεί τα μοτίβα και τον τρόπο επίθεσης, το κακόβουλο λογισμικό, τα εργαλεία, την ευπάθεια που εκμεταλλεύτηκαν οι δράστες και το σημαντικότερο, μέτρα περιορισμού που εφάρμοσαν για να προστατευτούν ή να ανακάμψουν από την απειλή.

Και όμως, μια τέτοια τεχνολογία υπάρχει, και ονομάζεται πληροφορίες για κυβερνοαπειλές (Cyber Threat Information - CTI). Είναι ένας μηχανισμός αναπαράστασης της γνώσης του κάθε οργανισμού ή αναλυτή ασφαλείας, για να είναι εύκολα “καταναλώσιμη” από τρίτους που θέλουν να προστατέψουν τους οργανισμούς τους. Με λίγα λόγια το CTI και ειδικότερα, ο διαμοιρασμός CTI επιτρέπει την επίτευξη ασφαλείας συνεργατικά.

Η μορφή των δεδομένων προς κατανάλωση για τις κυβερνοαπειλές διαδραματίζει μεγάλο ρόλο, καθώς πρέπει να είναι κατανοητή και δομημένη. Ένα πολύ χρήσιμο πρότυπο είναι η δομημένη έκφραση των πληροφοριών για τις απειλές (Structured Threat Information eXpression - STIX), το οποίο παρέχει δομημένη αναπαράσταση των κυβερνοαπειλών σε αντικείμενα και συσχετίσεις ώστε η εταιρεία που τις λαμβάνει να είναι σε θέση να κατανοήσει το περιεχόμενό τους. Ακόμα, είναι ιδιαίτερα σημαντικό οι πληροφορίες αυτές να είναι ποιοτικές και χρήσιμες. Η αξιολόγησή τους βασίζεται σε πολλαπλά κριτήρια, τα οποία αναλύονται στην συνέχεια.

2. ΘΕΩΡΗΤΙΚΟ ΥΠΟΒΑΘΡΟ

Σε αυτό το κεφάλαιο παρουσιάζονται οι βασικοί ορισμοί και αναλύονται οι έννοιες που είναι απαραίτητες για τον σκοπό της παρούσας πτυχιακής εργασίας.

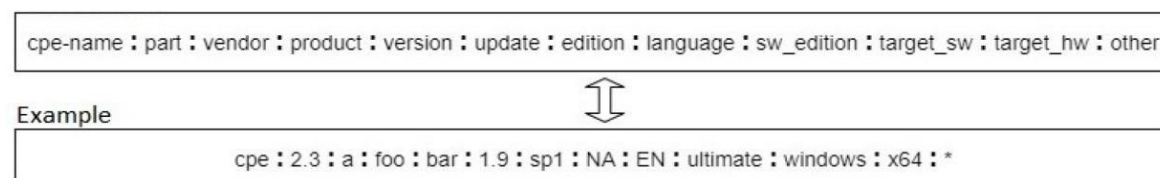
2.1. ΒΑΣΙΚΕΣ ΕΝΝΟΙΕΣ

Indicator of Compromise (IoC) [1], δηλαδή δείκτης παραβίασης, είναι μια ομάδα εγκληματολογικών δεδομένων, όπως για παράδειγμα δεδομένα που βρέθηκαν σε καταχωρήσεις αρχείων καταγραφής συστήματος (log file) ή σε αναλύσεις δικτυακής δραστηριότητας (network traffic). Πιο συγκεκριμένα, IoCs μπορεί να περιλαμβάνουν διευθύνσεις IP, διευθύνσεις URL, ονόματα ιστοχώρου (domain names), διευθύνσεις email, θέματα απεσταλμένων emails, links, επισυναπτόμενα αρχεία, αρχεία μητρώου συστήματος (registry keys), ονόματα αρχείων, συνόψιση περιεχομένου αρχείων (file hashes) και βιβλιοθήκες δυναμικής σύνδεσης (DLLs).

Course of Action (CoA) [2], δηλαδή συστάσεις προτεινόμενων ενεργειών, είναι ενέργειες που πρέπει να ακολουθηθούν σχετικά με τον τρόπο προστασίας ενός οργανισμού. Παραδείγματα τέτοιων ενεργειών αποτελούν, ο αποκλεισμός συγκεκριμένων θυρών (ports) ή ο αποκλεισμός συγκεκριμένων διευθύνσεων IP μέσω του τείχους προστασίας (firewall). Πρέπει να σημειωθεί ότι τα CoAs δεν αφορούν μια επίθεση, αλλά την αντιμετώπιση μιας συγκεκριμένης τεχνικής.

Common Vulnerabilities and Exposures (CVE) [3], δηλαδή κοινές ευπάθειες και εκθέσεις, είναι ευπάθειες (vulnerabilities) για λογισμικά και υλισμικά καταχωρημένα σε διαδικτυακά αποθετήρια, όπως για παράδειγμα αυτό που διατηρεί η MITRE [4] και το NIST [5]. Κάποιος μπορεί να αναφέρεται σε μια ευπάθεια π.χ. “Denial-of-Service (DoS) vulnerability in the Multi-Factor Authentication”, μέσω ενός μοναδικού αριθμού που η ευπάθεια διαθέτει (CVE ID number), στην συγκεκριμένη περίπτωση, την CVE-2021-29041 [6]. Τα CVE IDs εκχωρούνται από διάφορες αρχές αριθμοδότησης (CNAs). Οι CNAs εφόσον εντοπίσουν μια ευπάθεια μπορούν να την υποβάλλουν σε ένα διαδικτυακό αποθετήριο με CVEs, για παράδειγμα της MITRE [4]. Ένα CVE μπορεί επίσης να συνοδεύεται με μια σύντομη περιγραφή του και σχετικές αναφορές. Έπειτα από αξιολόγηση του εν λόγω υποβληθέντος CVE πραγματοποιείται η δημοσίευση του, με τη μορφή π.χ. “CVE-2019-1234567”.

Common Platform Enumeration (CPE) [7] είναι μια τυποποιημένη αναπαράσταση κατηγοριών εφαρμογών, λειτουργικών συστημάτων και συσκευών υλικού από το National Institute of Standards and Technology (NIST) [8]. Το CPE δεν περιγράφει συγκεκριμένες εφαρμογές, λειτουργικά συστήματα ή συσκευές, αλλά αφηρημένες κατηγορίες αυτών (δηλαδή κλάσεις). Για παράδειγμα δεν μπορεί να χρησιμοποιηθεί για την περιγραφή ενός υλισμικού με συγκεκριμένο σειριακό αριθμό (serial number), όπως για παράδειγμα ένα WIFI CISCO s/n 12345. Στην συγκεκριμένη περίπτωση θα περιέγραφε το μοντέλο WIFI, την εταιρεία και την έκδοση. Τα CPE έχουν την μορφή που παρουσιάζεται και μέσω ενός παραδείγματος στην Εικόνα 1:



Εικόνα 1: Μορφή και παράδειγμα ενός CPE

Common Attack Pattern Enumeration and Classification (CAPEC) [9], δηλαδή αρίθμηση και ταξινόμηση κοινών μοτίβων επίθεσης, είναι ένας δημόσια διαθέσιμος κατάλογος κοινών μοτίβων

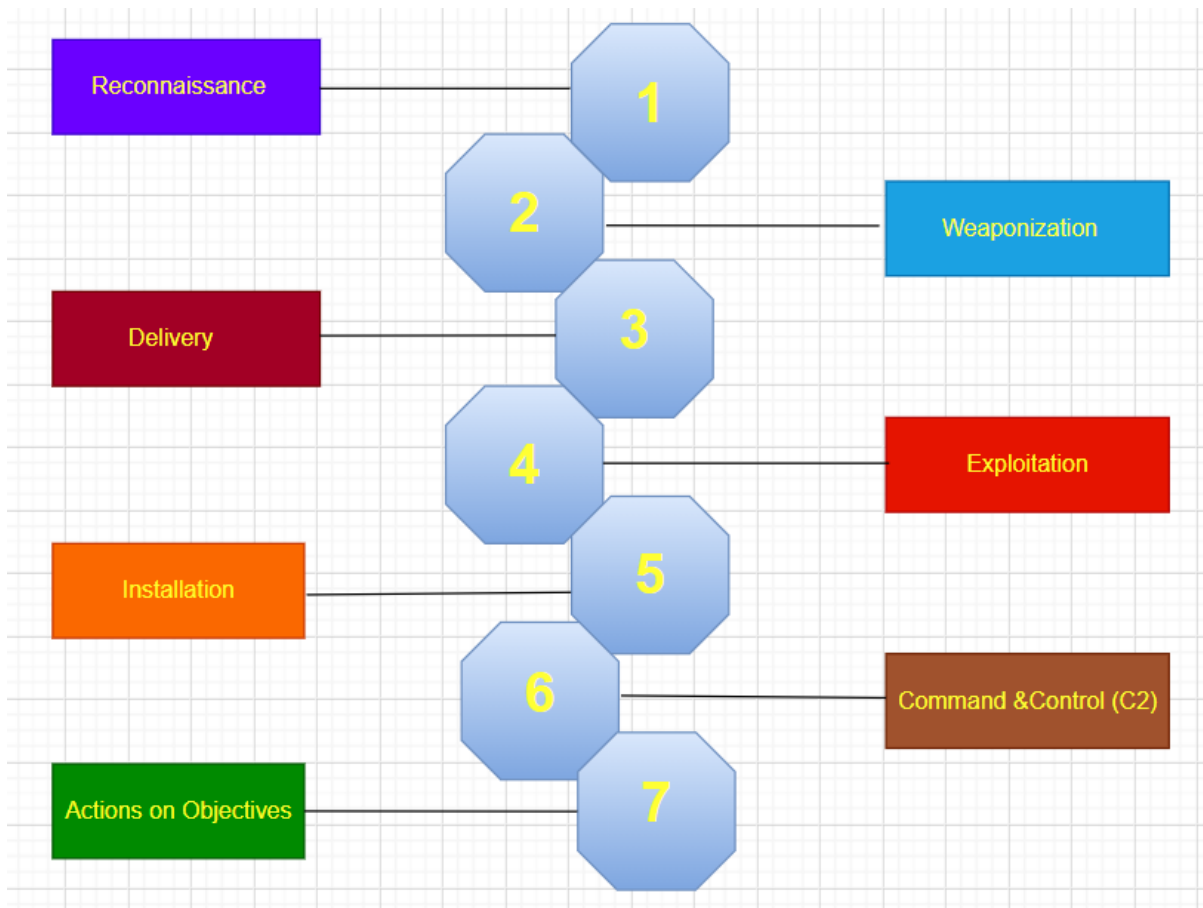
επίθεσης που προσφέρεται από την MITRE [10] και το NIST [11]. Κάθε CAPEC αφορά μια συγκεκριμένη επίθεση και περιγράφει τον τρόπο δράσης του επιτιθέμενου (modus operandi), δηλαδή τα βήματα που πρέπει να ακολουθήσει ώστε να πραγματοποιήσει επιτυχώς την επίθεση. Πιο συγκεκριμένα, ένα CAPEC περιέχει έναν μοναδικό αριθμό (Attack Pattern ID), μία περιγραφή του τρόπου δράσης, πιθανές σχέσεις με άλλα CAPEC, προαπαιτούμενα χαρακτηριστικά για να μπορεί να ξεκινήσει η επίθεση (π.χ. λειτουργικό σύστημα), τρόπους περιορισμού της επίθεσης και σχετικές κοινές αδυναμίες Common Weakness Enumeration (CWE) [12]. Τα CWE είναι γενικού τύπου ευπάθειες σε ένα λογισμικό ή υλισμικό. Η διαφορά τους με τα CVEs είναι ότι τα CWEs περιγράφουν γενικές ευπάθειες ως κλάσεις CVEs. Ένα CVE, επομένως, είναι μια συγκεκριμένη υλοποίηση ενός CWE.

Tactics, Techniques, and Procedures (TTPs) [13], δηλαδή τακτικές, τεχνικές και διαδικασίες, είναι η περιγραφή της συμπεριφοράς ενός επιτιθέμενου. Η εν λόγω περιγραφή πραγματοποιείται με τους τρεις όρους, ήτοι τακτικές, τεχνικές και διαδικασίες. Μια τακτική περιγράφει την συμπεριφορά ενός επιτιθέμενου σε αφαιρετικούς όρους. Η τακτική αναλύεται περισσότερο μέσω των τεχνικών. Τέλος, οι διαδικασίες χρησιμοποιούνται για να περιγράψουν μια τεχνική με πολύ υψηλή λεπτομέρεια.

Kill Chain (KC) [14], δηλαδή αλυσίδα επίθεσης, είναι ένα μοντέλο που βασίζεται σε φάσεις για να περιγράψει τα στάδια μιας επίθεσης. Η ανάλυση μιας επίθεσης σε στάδια, από την συλλογή πληροφοριών μέχρι την επιτυχή ολοκλήρωση της, είναι χρήσιμη στην κατανόηση επιθέσεων για τον σκοπό της πρόληψης, ανίχνευσης και απόκρισης σε αυτές. Στην βιβλιογραφία, έχουν προταθεί διάφορα μοντέλα KC, με το περισσότερο γνωστό αυτό της Lockheed Martin που ονομάζεται Cyber Kill Chain (CKC) [15]. Τα στάδια της CKC περιγράφονται ως εξής:

1. Αναγνώριση (Reconnaissance): Συλλογή πληροφοριών για τον στόχο. Για παράδειγμα σάρωση δικτύου, θυρών και εφαρμογών ενός συστήματος για αναγνώριση ευπαθειών τις οποίες ο επιτιθέμενος μπορεί να εκμεταλλευτεί.
2. Οπλισμός (Weaponization): Δημιουργία ενός κακόβουλου προγράμματος το οποίο μπορεί να εκμεταλλευτεί αδυναμίες του στόχου που βρέθηκαν στο στάδιο 1.
3. Παράδοση (Delivery): Τρόπος παράδοσης του κακόβουλου κώδικα που δημιουργήθηκε στο στάδιο 2. Ένα παράδειγμα τρόπου παράδοσης αποτελεί το ψάρεμα ηλεκτρονικού ταχυδρομείου (email phishing) κατά το οποίο ο επιτιθέμενος παριστάνει μια έμπιστη πηγή (π.χ. έναν συνεργάτη), ώστε ο στόχος να εξαπατηθεί και να εγκαταστήσει τον κακόβουλο κώδικα του σταδίου 2.
4. Εκμετάλλευση (Exploit): Η εκμετάλλευση της αδυναμίας που βρέθηκε στο στάδιο 1, από το κακόβουλο πρόγραμμα που δημιουργήθηκε στο στάδιο 2. Για παράδειγμα, ένα malware κατάφερε να αποκτήσει πρόσβαση στο σύστημα του στόχου εκμεταλλευόμενο μια ευπάθεια στο σύστημα των Windows, την CVE-2021-28356 [16], στην οποία καταφέρνει ο επιτιθέμενος να εκτελέσει απομακρυσμένες εντολές.
5. Εγκατάσταση (Installation): Η εγκατάσταση του κακόβουλου κώδικα στο σύστημα ώστε να επιτύχει την παραμονή του σε αυτό ακόμη και σε περίπτωση επανεκκίνησης του συστήματος. Για παράδειγμα, η εγκατάσταση του κακόβουλου λογισμικού στον φάκελο εκκίνησης (startup folder) ώστε να εκτελείται ο κακόβουλος κώδικας μετά την επανεκκίνηση του συστήματος.
6. Εντολή και έλεγχος (Command and Control -C2): Ο κακόβουλος κώδικας ιδρύει ένα κανάλι επικοινωνίας μεταξύ αυτού και του επιτιθέμενου ώστε να μεταφέρονται οι εντολές στο σύστημα του στόχου. Ενέργειες που πραγματοποιούνται σε αυτό το στάδιο είναι για παράδειγμα η εγκατάσταση και άλλων εργαλείων στον στόχο ώστε να διευκολύνεται το τελευταίο στάδιο της επίθεσης του επιτιθέμενου.
7. Ενέργειες (Actions on objectives): Η ολοκλήρωση των ενεργειών του επιτιθέμενου. Για παράδειγμα, η προβολή ή τροποποίηση ευαίσθητων δεδομένων του στόχου, ή και η περαιτέρω διείσδυση στο δίκτυο του οργανισμού του στόχου.

Τα στάδια του CKC συνοψίζονται και στην παρακάτω Εικόνα 2.



Εικόνα 2: Martin Lockheed's Cyber Kill Chain

Εάν ένας οργανισμός αναφέρεται ονομαστικά σε στάδιο που δεν υπάρχει στην CKC, λέμε ότι χρησιμοποιεί δικιά του KC. Για παράδειγμα το ATT&CK framework της MITRE [17], διαθέτει την δική της KC (ATT&CK KC) [18] η οποία περιέχει περισσότερα στάδια από την CKC: 1) Initial Access, 2) Execution, 3) Persistence, 4) Privilege Escalation, 5) Defense Evasion, 6) Credential Access, 7) Discovery, 8) Lateral Movement, 9) Collection, 10) Command and Control, 11) Exfiltration, 12) Impact.

Το Trusted Automated eXchange of Indicator Information (TAXII) [19] καθορίζει τον τρόπο με τον οποίο οι πληροφορίες για την απειλή στον κυβερνοχώρο μπορούν να κοινοποιούνται μέσω υπηρεσιών και ανταλλαγών μηνυμάτων. Για την κοινοποίηση των πληροφοριών χρησιμοποιούνται TAXII διακομιστές, που λειτουργούν με βάση το μοντέλο πελάτη διακομιστή (client-server). Υπάρχουν παραγωγοί πληροφοριών για κυβερνοαπειλές, που τις παρέχουν στον TAXII διακομιστή και υπάρχουν καταναλωτές που ζητάνε αυτές τις πληροφορίες από τον διακομιστή. Στην παρούσα πτυχιακή παίρνουμε πρόσβαση σε TAXII διακομιστές πηγών με τη χρήση της βιβλιοθήκης taxii2-client [20].

2.2. CYBER THREAT INFORMATION

Στη βιβλιογραφία υπάρχουν δύο όροι για τις πληροφορίες για τις κυβερνοαπειλές, Cyber Threat Information και Cyber Threat Intelligence (CTI) οι οποίοι χρησιμοποιούνται εναλλακτικά. Επίσης, σε άλλες αναφορές [21], χρησιμοποιείται και ο όρος Cyber Threat Information and Intelligence (CTII). Στην παρούσα πτυχιακή εργασία ακολουθούμε τον όρο Cyber Threat Information του NIST SP 800-150 [22]. Μια κυβερνοαπειλή (cyber threat) είναι κάθε περίπτωση ή γεγονός που μπορεί να επηρεάσει αρνητικά τις λειτουργίες, την εικόνα, τα περιουσιακά στοιχεία ενός οργανισμού μέσω μη εξουσιοδοτημένης πρόσβασης, καταστροφής, αποκάλυψης ή τροποποίησης πληροφοριών, ή και

άρνηση της υπηρεσίας στους εξουσιοδοτημένους χρήστες (denial of service). Ως CTI ορίζεται κάθε πληροφορία που σχετίζεται με μια κυβερνοαπειλή που μπορεί να βοηθήσει έναν οργανισμό να προστατευθεί ενάντια σε μια επίθεση ή να εντοπίσει τις ενέργειες ενός επιτιθέμενου. Ένα CTI μπορεί να περιλαμβάνει IoCs, TTPs, CoAs και άλλες πληροφορίες (π.χ., CVEs).

Ο διαμοιρασμός CTI (CTI sharing) παρέχει πρόσβαση σε πληροφορίες κυβερνοαπειλών που διαφορετικά δεν θα ήταν διαθέσιμες σε έναν οργανισμό. Χρησιμοποιώντας κοινόχρηστους πόρους, οι οργανισμοί μπορούν να βελτιώσουν την στρατηγική ασφαλείας τους, αξιοποιώντας τις γνώσεις, τις εμπειρίες και τις δυνατότητες των συνεργατών τους με εποικοδομητικό τρόπο. Έτσι, η ανίχνευση των απειλών ενός οργανισμού, γίνεται η προστασία από τις απειλές αυτές σε έναν άλλο οργανισμό, γεγονός που μπορεί να βελτιώσει την συνολική ασφάλεια των εταιρειών που μοιράζονται ενεργά CTI. Ένας οργανισμός μπορεί να χρησιμοποιήσει το CTI με διάφορους τρόπους. Στην βιβλιογραφία αναφέρονται 4 κατηγορίες [23]:

1. Στρατηγικό CTI (Strategic CTI): Πρόκειται για πληροφορίες υψηλού επιπέδου και καταναλώνονται από εκείνους που ελέγχουν τη στρατηγική ενός οργανισμού, συνήθως από τους υπεύθυνους διοίκησης. Το επίκεντρο του στρατηγικού CTI βρίσκεται στις πτυχές μιας κυβερνοαπειλής που μπορεί να επηρεάσει τις επιχειρηματικές αποφάσεις.
2. Λειτουργικό CTI (Operational CTI): Πρόκειται για πληροφορίες που αφορά συγκεκριμένα έναν οργανισμό όπου υπάρχει συνάφεια με τις άμεσες επιχειρηματικές δραστηριότητες αυτού του οργανισμού. Το λειτουργικό CTI μπορεί να παραχθεί με ταχύτερο ρυθμό και μπορεί να χρησιμοποιηθεί για να προειδοποιήσει τους ειδικούς ασφαλείας για μια επικείμενη επίθεση.
3. Τακτικό CTI (Tactical CTI): Πρόκειται για συγκεκριμένες πληροφορίες που σχετίζονται με TTPs που χρησιμοποιούνται από έναν επιτιθέμενο.
4. Τεχνικό CTI (Technical CTI): Πρόκειται για πιο τεχνικές πληροφορίες που παρέχονται μέσω IoCs. Σε ορισμένες περιπτώσεις, αυτές οι πληροφορίες μπορεί να καταναλωθούν απευθείας από αμυντικούς μηχανισμούς, όπως από τείχη προστασίας (firewall), συστήματα ανίχνευσης εισβολών (Intrusion Detection Systems) ή συστήματα πρόληψης εισβολών (Intrusion Prevention Systems).

2.3. STRUCTURED THREAT INFORMATION EXPRESSION

Το Structured Threat Information eXpression (STIX) είναι μια γλώσσα σήμανσης με ένα σύνολο κανόνων για δημιουργία, ανταλλαγή και κατανάλωση CTI [24]. Το STIX αποτυπώνει με σαφήνεια ένα CTI με δομημένο τρόπο κατάλληλο για επεξεργασία από μηχανή. Πληροφορίες CTI εκφραζόμενες σε γλώσσα STIX δύναται να παρουσιαστούν με κατάλληλη οπτικοποίηση σε έναν αναλυτή ή να αποθηκευτούν σε μορφή JSON ή XML, ώστε να μπορούν να υποστούν επεξεργασία από αυτοματοποιημένες διαδικασίες. Το STIX επιλέχθηκε ως το πρότυπο (standard) στο διαμοιρασμό πληροφοριών μεταξύ Ευρωπαϊκών οργανισμών [25]. Στην 2η έκδοση του STIX (STIX2) [24], την οποία χρησιμοποιούμε στην παρούσα εργασία, ένα CTI περιγράφεται με τα αντικείμενα που ονομάζονται STIX Core Objects. Στα Core Objects περιέχονται τα:

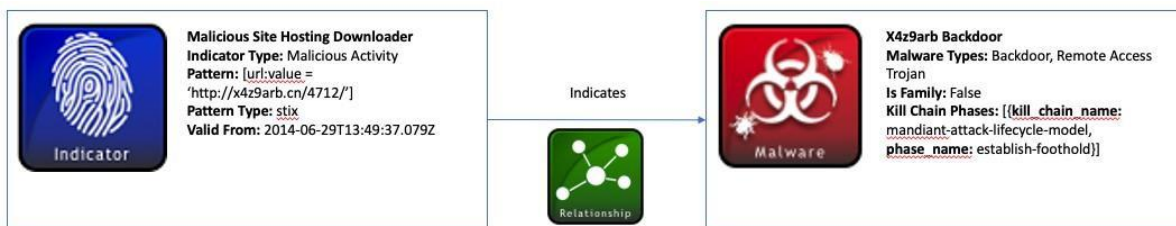
- SDO (STIX Domain Objects) που αντιπροσωπεύουν έννοιες στον κυβερνοχώρο (π.χ. malware, IoC) αλλά και συμπεριφορές των επιτιθέμενων (π.χ., TTPs). Μερικά παραδείγματα SDO είναι: Attack Pattern, Campaign, Course of Action, Grouping, Identity, Indicator, Infrastructure, Intrusion Set, Location, Malware, Malware Analysis, Note, Observed Data, Opinion, Report, Threat Actor, Tool, και Vulnerability.
- SCO (STIX Cyber-observable Objects) που περιέχουν περισσότερο τεχνικής φύσεως πληροφορία για ένα δίκτυο ή υπολογιστή (π.χ. διεύθυνση IP, αρχεία κειμένου, διευθύνσεις email). Τα SCOs μπορούν να χρησιμοποιηθούν μέσα σε SDOs για να τα εμπλουτίσουν. Μερικά

παραδείγματα SCOs είναι Artifact, Autonomous System, Directory, Domain Name, Email Address, File, URL, X509 Certificate κ.τ.λ.

- SRO (STIX Relationship Objects) που είναι αντικείμενα που συνδέουν SDOs και SCOs μεταξύ τους. Με άλλα λόγια τα SRO αναπαριστούν τις συσχετίσεις μεταξύ SDOs και SCOs. Τα διαθέσιμα SRO είναι τα: Relationship και Sighting SRO.

Ένα ενδεικτικό παράδειγμα χρήσης της γλώσσας STIX2 είναι αυτό που ακολουθεί, σχετικά με την περιγραφή ενός δείκτη παραβίασης κακόβουλου URL στο οποίο βρίσκεται ένα malware [26]. Μια πολύ συχνή μέθοδος για την παράδοση κακόβουλου λογισμικού σε πιθανούς στόχους είναι η φιλοξενία του σε μια συγκεκριμένη διεύθυνση (URL). Στη συνέχεια, οι στόχοι (δηλαδή τα θύματα μιας επίθεσης) μπορεί να κατευθύνονται σε αυτήν τη διεύθυνση μέσω “ψαρέματος” ηλεκτρονικού ταχυδρομείου (email phishing) ή μέσω ενός συνδέσμου από έναν άλλον ιστότοπο και, όταν φτάσουν σε αυτόν, να εκτελείται ο κακόβουλος κώδικας που ονομάζεται payload ή malware. Η κοινοποίηση λιστών κακόβουλων διευθύνσεων URL μπορεί να είναι ένας αποτελεσματικός τρόπος για τον περιορισμό της έκθεσης σε κακόβουλο κώδικα. Στο συγκεκριμένο παράδειγμα [26], υπάρχει μια ένδειξη (Indicator SDO) για τη διεύθυνση URL <http://x4z9arb.cn/4712/>, η οποία είναι γνωστό ότι είναι κακόβουλη, καθώς και ένα τμήμα κακόβουλου λογισμικού (Malware SDO) που σχετίζεται με τη διεύθυνση URL.

- Οι κακόβουλες τιμές URL μπορούν να αναπαρασταθούν χρησιμοποιώντας ένα SDO, συγκεκριμένα, ένα Indicator SDO. Έτσι, η διεύθυνση URL μπορεί να δομηθεί χρησιμοποιώντας μια έκφραση σύγκρισης: `[url: value = 'http://x4z9arb.cn/4712/']`. Το Indicator SDO πρέπει επίσης να περιέχει μια ιδιότητα `indicator_types` που παρέχει περισσότερη πληροφορία σχετικά με τη διεύθυνση URL. Η διεύθυνση URL σε αυτό το σενάριο είναι γνωστό ότι είναι κακόβουλη, οπότε ο κατάλληλος τύπος για αυτόν τον δείκτη είναι “κακόβουλη δραστηριότητα” (malicious activity). Αυτή η τιμή προέρχεται από ένα ανοιχτό λεξιλόγιο του τύπου Indicator SDO [27] που περιέχει και άλλους χρήσιμους τύπους για την κατηγοριοποίησή τους. Ένα άλλο απαιτούμενο πεδίο για το Indicator SDO που ονομάζεται `valid_from` υπαγορεύει την χρονική στιγμή από την οποία αυτή η διεύθυνση URL είναι έγκυρη (valid from). Σε αυτήν την περίπτωση, η διεύθυνση URL είναι έγκυρη από τη στιγμή της δημιουργίας του Indicator SDO.
- Το κακόβουλο λογισμικό που σχετίζεται με το URL σε αυτό το σενάριο είναι ένας τύπος “εναλλακτικής εισόδου” (backdoor) και μπορεί να μοντελοποιηθεί χρησιμοποιώντας το Malware SDO. Όπως με το Indicator SDO, τα Malware SDO μπορούν να ταξινομηθούν περαιτέρω χρησιμοποιώντας μια ιδιότητα `malware_types` που προέρχεται από το ανοιχτό λεξιλόγιο κακόβουλων λογισμικών [27] του STIX2. Για παράδειγμα, ένα κακόβουλο λογισμικό μπορεί να ταξινομηθεί ως `keylogger`, `spyware`, `worm`, `virus` κ.λπ. Σε αυτό το παράδειγμα, το κακόβουλο λογισμικό που συνδέεται με τη διεύθυνση URL είναι ένας τύπος backdoor και δούρειος ίππος απομακρυσμένης πρόσβασης (remote access trojan). Ένα Malware SDO μπορεί επίσης να είναι χρήσιμο για την καταγραφή πληροφοριών KC σχετικά με την παρουσία κακόβουλου λογισμικού. Είναι γνωστό ότι αυτό το malware επιχειρεί να δημιουργήσει ένα backdoor στο σύστημα και να κατεβάσει απομακρυσμένα αρχεία. Επομένως, το Malware SDO δύναται να περιέχει μια λίστα `kill_chain_phases` που σχετίζονται με τις αντίστοιχες φάσεις της KC. Στο παράδειγμα, χρησιμοποιείται η KC της Mandiant και εντάσσεται στην φάση της απόκτησης του ελέγχου (establish foothold).
- Τέλος, μπορεί να χρησιμοποιηθεί ένα Relationship SRO για τη σύνδεση των Indicator και Malware SDO. Η ένδειξη URL δείχνει το αντικείμενο κακόβουλου λογισμικού, οπότε το πεδίο `relationship_type` θα πάρει την τιμή “indicates”. Ένα διάγραμμα αυτής της σχέσης φαίνεται στην Εικόνα 3. Σε αυτήν τη σχέση, όπως δείχνει η Εικόνα 4, το αναγνωριστικό (id) του Indicator SDO είναι το πεδίο `source_ref` και το αναγνωριστικό του Malware SDO είναι το πεδίο `target_ref`.



Εικόνα 3: Παράδειγμα σχέσης μεταξύ δύο SDO

Στην Εικόνα 4 παρουσιάζεται το ανωτέρω παράδειγμα της Εικόνας 3 σε STIX2:

```

1  {
2    "type": "bundle",
3    "id": "bundle--56be2a3b-1534-4bef-8fe9-602926274009",
4    "objects": [
5      {
6        "type": "indicator",
7        "spec_version": "2.1",
8        "id": "indicator--d81f86b9-975b-4c0b-875e-810c5ad45a4f",
9        "created": "2014-06-29T13:49:37.079Z",
10       "modified": "2014-06-29T13:49:37.079Z",
11       "name": "Malicious site hosting downloader",
12       "description": "This organized threat actor group operates to create profit from all types of crime.",
13       "indicator_types": [
14         "malicious-activity"
15       ],
16       "pattern": "[url:value = 'http://x4z9arb.cn/4712/']",
17       "pattern_type": "stix",
18       "valid_from": "2014-06-29T13:49:37.079Z"
19     },
20     {
21       "type": "malware",
22       "spec_version": "2.1",
23       "id": "malware--162d917e-766f-4611-b5d6-652791454fca",
24       "created": "2014-06-30T09:15:17.182Z",
25       "modified": "2014-06-30T09:15:17.182Z",
26       "name": "x4z9arb backdoor",
27       "description": "This malware attempts to download remote files after establishing a foothold as a backdoor.",
28       "malware_types": [
29         "backdoor",
30         "remote-access-trojan"
31       ],
32       "is_family": false,
33       "kill_chain_phases": [
34         {
35           "kill_chain_name": "mandiant-attack-lifecycle-model",
36           "phase_name": "establish-foothold"
37         }
38       ]
39     },
40     {
41       "type": "relationship",
42       "spec_version": "2.1",
43       "id": "relationship--864af2ea-46f9-4d23-b3a2-1c2adf81c265",
44       "created": "2020-02-29T18:03:58.029Z",
45       "modified": "2020-02-29T18:03:58.029Z",
46       "relationship_type": "indicates",
47       "source_ref": "indicator--d81f86b9-975b-4c0b-875e-810c5ad45a4f",
48       "target_ref": "malware--162d917e-766f-4611-b5d6-652791454fca"
49     }
50   ]
51 }

```

Εικόνα 4: Παράδειγμα σχέσης μεταξύ δύο SDO με ένα SRO σε STIX2 format

Οι πηγές CTI (CTI source) όπως τα McAfee Advanced Threat Defense, ThreatConnect και SolarWinds Threat Monitor [28] είναι αποθετήρια που διευκολύνουν τον διαμοιρασμό CTI. Στην παρούσα έρευνα ένα διαμοιραζόμενο CTI εκφραζόμενο σε δομημένη μορφή κατάλληλη (π.χ., CSV, JSON, XML, STIX) αναφέρεται ως CTI Product (CTIP). Τα CTIPs αναλύονται από τους καταναλωτές CTI (στελέχη ασφαλείας πληροφοριών του εκάστοτε οργανισμού), οι οποίοι εγγράφονται σε τέτοιες πηγές για να λαμβάνουν αυτές τις πληροφορίες και να μπορούν να τις χρησιμοποιήσουν σε αυτοματοποιημένες λύσεις ελέγχου ασφαλείας (π.χ., αποκλεισμό (blacklist) συγκεκριμένων κακόβουλων διευθύνσεων IP σε ένα firewall). Για να μπορέσει να χρησιμοποιηθεί ένα CTIP στις αυτοματοποιημένες λύσεις αυτές, πρέπει να προσφέρει ωφέλιμες πληροφορίες. Για αυτόν τον λόγο, υπάρχουν κριτήρια με βάση τα οποία μπορεί να αξιολογηθεί η ποιότητα τους.

3. ΠΟΙΟΤΙΚΑ ΚΡΙΤΗΡΙΑ ΓΙΑ ΤΗΝ ΑΞΙΟΛΟΓΗΣΗ ΚΥΒΕΡΝΟΑΠΕΙΛΩΝ

Ως ποιοτικό κριτήριο εννοούμε μια μετρική με την οποία μπορούμε να βγάλουμε κάποιο συμπέρασμα για την ποιότητα ενός συνόλου δεδομένων (εν προκειμένω ενός CTIP). Με βάση τη βιβλιογραφία, υπάρχουν 4 κριτήρια ποιοτικής αξιολόγησης CTIPs: Φρεσκάδα (Timeliness), Πληρότητα (Sensitivity), Πρωτοτυπία (Originality), Επίπτωση (Impact) [29].

3.1. ΦΡΕΣΚΑΔΑ

Προκειμένου να προστατευθούν από τις αναδυόμενες απειλές, πολλοί οργανισμοί εγγράφονται σε πηγές CTI που για παράδειγμα προσφέρουν κακόβουλα ονόματα ιστοχώρων (domain names) ή κακόβουλες διευθύνσεις IP. Ο στόχος της εγγραφής σε μια τέτοια πηγή είναι η λήψη έγκαιρης προειδοποίησης για μια επικίνδυνη κακόβουλη δραστηριότητα που σχετίζεται με κάποιο κακόβουλο ιστότοπο ή IP. Μια τέτοια έγκαιρη προειδοποίηση έχει ως αποτέλεσμα η ζημιά να περιοριστεί στο δίκτυο περιοχής που συνέβη και να αντιμετωπιστεί εγκαίρως η περαιτέρω της εξάπλωση. Όσο πιο νωρίς λοιπόν, δημιουργούνται CTIPs για κακόβουλες IP διευθύνσεις και domain names, τόσο υψηλότερη είναι η χρησιμότητα της πηγής (και του CTIP) στον συνδρομητή της. Επομένως τόσο υψηλότερη είναι και η ποιότητα των περιεχομένων των πληροφοριών αυτών.

Η φρεσκάδα, επομένως, είναι ένα ποιοτικό κριτήριο που σχετίζεται με την χρονολογία δημιουργίας ενός CTIP και δείχνει την επικαιρότητα του CTIP. Ένα βασικό ποιοτικό κριτήριο των CTIPs είναι επομένως και πόσο επίκαιρα οι απειλές δημοσιεύονται. Με άλλα λόγια, είναι το πόσο σύντομα ένα κακόβουλο περιστατικό, περιλαμβάνεται σε τέτοιες λίστες αφού ξεκινήσει περίεργες δραστηριότητες. Η άμεση γνωστοποίηση θα ελαχιστοποιήσει το ποσοστό των αρνητικών αποτελεσμάτων που θα μπορούσαν να προκληθούν στο πλαίσιο μιας επίθεσης. Αυτό συμβαίνει λόγω της μείωσης του χρονικού διαστήματος κατά το οποίο τα συστήματα βρίσκονται υπό τον έλεγχο του επιτιθέμενου.

Στα CTIPs είναι σημαντικό αυτό το κριτήριο καθώς, η τεχνολογία εξελίσσεται με ραγδαίους ρυθμούς, το ίδιο εξελίσσονται και οι απειλές. Ένα πρόσφατο CTIP οδηγεί στο να προλάβει ο οργανισμός που θα το καταναλώσει να προετοιμαστεί και να αναπτύσσει τις απαραίτητες άμυνες έγκαιρα. Ένα τέτοιο πολύ σχετικό παράδειγμα είναι τα zero day attacks. Μια zero day επίθεση αφορά στην εκμετάλλευση (exploit) μιας ευπάθειας (vulnerability) προτού οι προγραμματιστές και οι διαχειριστές του συστήματος την αντιληφθούν. Ένα CTIP το οποίο δίνει πληροφορίες και οδηγίες για την αντιμετώπιση (π.χ., update σε κάποιο software) μιας τόσο πρόσφατης αδυναμίας, είναι υψίστης χρησιμότητας για τους οργανισμούς που θα το καταναλώσουν. Γενικότερα, ένας οργανισμός, με προσωπικό κυβερνοασφάλειας, θεωρητικά θα έχει εξασφαλίσει την θωράκιση του οργανισμού ενάντια σε απειλές χρονολογικά παλιές και γνωστές στον χώρο. Οπότε τα πρόσφατα CTIP στην πράξη ενδιαφέρουν περισσότερο τους οργανισμούς, για αυτό και το ποιοτικό κριτήριο της φρεσκάδας είναι ένα από αυτά που μπορούν να χρησιμοποιηθούν στη πράξη για την αξιολόγηση των CTIPs. Μια άλλη άποψη είναι ότι, δεν έχουν προστατευθεί πλήρως όλοι οι οργανισμοί από τις παλαιότερες και πιο γνωστές απειλές, οπότε ένας οργανισμός μπορεί να ενδιαφέρεται και για την κατανάλωση CTIPs των οποίων η χρονολογία προσθήκης δεν είναι τόσο πρόσφατη. Το συμπέρασμα είναι λοιπόν ότι η φρεσκάδα είναι πολύ σημαντική στην αξιολόγηση των CTIPs για όλους τους οργανισμούς, αλλά και η παλαιότητα των δεδομένων επίσης, δεν είναι πάντα απαγορευτική στη χρήση του.

Στην έρευνα, το κριτήριο της φρεσκάδας αξιολογήθηκε με βάση το έτος καταχώρισης του κάθε CTIP από την κάθε πηγή. Τα αποτελέσματα της φρεσκάδας της κάθε πηγής, στο Κεφάλαιο 7.1, προκύπτουν με βάση την μέτρηση του πλήθους των CTIPs της κάθε πηγής ανά χρονολογικό έτος δια του συνόλου των CTIPs της, επί εκατό.

3.2. ΠΛΗΡΟΤΗΤΑ

Η πληρότητα είναι ένα από τα κριτήρια που μπορεί να χρησιμοποιηθεί για την αξιολόγηση των CTIPs. Μια πηγή CTI πρέπει να παρέχει CTIPs που να είναι πλήρη. Ένας οργανισμός ο οποίος εγγράφεται σε μια πηγή CTI για να καταναλώσει CTIPs, αναζητά πληροφορίες για να τον βοηθήσουν να κατανοήσει την απειλή. Πρακτικά λοιπόν αναζητά ένα CTIP το οποίο προσφέρει όσο το δυνατό περισσότερες πληροφορίες για μια απειλή. Για παράδειγμα, να αναφέρει την συχνότητα εμφάνισης μιας

κακόβουλης δραστηριότητας, τους κινδύνους που επιφυλάσσει, τους τύπους οργανισμών που κινδυνεύουν, την γεωγραφική κάλυψη της απειλής, τον τρόπο αντιμετώπισης της. Από την άλλη μεριά, ένα CTIP που αφορά κακόβουλο λογισμικό (malware) και δεν δίνει κάποιες, αν όχι όλες, από τις πιο σημαντικές πληροφορίες όπως την ονομασία του, τότε παρουσιάστηκε για πρώτη φορά, σε ποια λειτουργικά συστήματα επιτίθεται, τι επιπτώσεις μπορεί να επιφέρει σε έναν οργανισμό και σε ποιο στάδιο της KC χρησιμοποιείται, δεν αποτελεί αξιόλογο CTIP για να ληφθεί υπόψη από έναν οργανισμό.

Με την πληρότητα λοιπόν, εκτιμούμε τι όγκο δεδομένων είναι απαραίτητο ένα CTIP να περιέχει ώστε να βοηθήσει στην πληρέστερη κατανόηση μιας απειλής. Ένα CTIP είναι πλήρες εάν περιέχει τιμές σε όλα τα πεδία του σχήματος (π.χ., STIX) που χρησιμοποιεί. Ένα τέτοιο CTIP περιέχει όλες τις δυνατές πληροφορίες που επιτρέπει το σχήμα και επομένως μπορεί να καθοδηγήσει τον οργανισμό που θα το χρησιμοποιήσει να κατανοήσει την απειλή όσο το δυνατόν καλύτερα.

Στην έρευνα, το ποιοτικό κριτήριο της πληρότητας, αξιολογήθηκε με βάση τα πεδία των SDO που υπάρχουν στο σχήμα του STIX2 [30]. Πιο συγκεκριμένα, δημιουργείται ένα ποσοστό μεταξύ του πλήθους των υπάρχοντων πεδίων σε ένα SDO των πηγών CTI, δια το σύνολο των πεδίων του STIX2 σχήμα, επί 100. Για παράδειγμα, ένα Attack Pattern SDO (μοτίβο επίθεσης), στο STIX2 σχήμα, μπορεί να περιέχει τα πεδία: type, aliases, id, name, description, kill_chain_phases. Έξι πεδία στο σύνολο τους. Έτσι, αν μια πηγή περιέχει Attack Pattern SDOs και μέσα σε αυτό περιέχονται μόνο τα πεδία: types, id, name, description που είναι τέσσερα στο σύνολο βγαίνει ένα ποσοστό της τάξης τέσσερα διά έξι επί εκατό, περίπου 67% πληρότητα στο συγκεκριμένο SDO.

3.3. ΠΡΩΤΟΤΥΠΙΑ

Στη πράξη ένας οργανισμός πιθανότατα εγγράφεται σε πολλές πηγές για λήψη CTIPs, καθώς οι πηγές συχνά ειδικεύονται σε έναν συγκεκριμένο τύπο απειλών. Οι πηγές, ωστόσο, χρησιμοποιούν και αναπαράγουν απειλές από άλλες πηγές και τις προσφέρουν σαν δική τους υπηρεσία.

Μια βασική μέτρηση των CTIPs είναι επομένως η πρωτοτυπία. Με άλλα λόγια το πόσο οι πληροφορίες μια πηγής είναι μοναδικές και δεν θα μπορούσαν να ληφθούν από άλλη πηγή. Έτσι, ένας υψηλός βαθμός πρωτοτυπίας οδηγεί στο συμπέρασμα ότι μια πηγή προσφέρει δείγματα μοναδικά τα οποία δηλαδή δεν τα λαμβάνει από άλλη πηγή. Αυτό, ωστόσο σημαίνει ότι ένας οργανισμός πρέπει να συνδεθεί σε περισσότερες πηγές, ώστε να είναι σίγουρος ότι έχει αντλήσει επαρκή διαφορετικά CTIPs και να μην χάσει πληροφορίες για απειλές.

Στην πράξη η αξιολόγηση της πρωτοτυπίας των CTIPs είναι υπολογιστικά δύσκολη (NP-hard), καθώς οι πηγές θα πρέπει διαρκώς να συγκρίνουν τα CTIPs που παράγουν με αυτά των ανταγωνιστών ώστε να εξαλειφθούν οι “ανακυκλώσεις” των πληροφοριών, διατηρώντας έτσι την μοναδικότητα του κάθε CTIP. Η πρωτοτυπία καλό είναι να υπάρχει, αλλά δεν είναι εφικτό στη πράξη να χρησιμοποιηθεί ως ποιοτικό κριτήριο. Για να γίνει αυτό χρειάζεται το κάθε CTIP της κάθε πηγής να συγκριθεί με όλα τα CTIPs όλων των άλλων πηγών. Το υπολογιστικό κόστος σε αυτή την περίπτωση είναι τεράστιο τόσο σε σχέση υπολογισμών, όσο και σε σχέση άντλησης όλων των CTIPs από κάθε πηγή σε καθημερινή βάση. Ακόμη και να ήταν υπολογιστικά εφικτό θα έπρεπε να δημιουργηθούν κατάλληλοι αλγόριθμοι που επιτρέπουν σύγκριση CTIPs. Για παράδειγμα αλγόριθμοι ομοιότητας (similarity) CTIPs. Τέλος, η

διαφορετικότητα των σχημάτων που χρησιμοποιούν οι πηγές (π.χ., non-STIX, STIX) δυσχεραίνει ακόμη περισσότερο την κατάσταση.

3.4. ΕΠΙΠΤΩΣΗ

Όταν ένας οργανισμός αξιοποιεί τις πληροφορίες από τα CTIPs, αυτό θα πρέπει να οδηγεί στον μετριασμό μιας συγκεκριμένης απειλής. Όμως, η αξιοποίηση των CTIPs μπορεί να έχει και αρνητικές συνέπειες ειδικά εάν οι πληροφορίες δεν είναι αρκετά συγκεκριμένες και ακριβείς. Είναι ιδιαίτερα ανησυχητικό, αν τα CTIPs παρέχουν για παράδειγμα, μόνο μια κακόβουλη διεύθυνση IP χωρίς περαιτέρω πληροφορίες όπως για παράδειγμα με ποιον διακομιστή σχετίζεται. Αν αυτή η IP σχετίζεται με εμπορικές υπηρεσίες νέφους (cloud), ο αποκλεισμός της οδηγεί σε πλήρη αποκλεισμό της εν λόγω υπηρεσίας. Πράγματι υπάρχουν περιπτώσεις όπου ένας επιτιθέμενος (threat actor) χρησιμοποιεί τις υπηρεσίες εμπορικών υποδομών, καθώς αυτό προσφέρει πολύ μεγαλύτερη ευελιξία, δυσκολία εντοπισμού και δεν προκαλούνται αρνητικές συνέπειες όπως η κατάσχεση του προσωπικού υλικού του επιτιθέμενου. Αυτό όμως σημαίνει ότι ο αποκλεισμός της συγκεκριμένης IP οδηγεί σε αποκλεισμό των υπηρεσιών νέφους ως παράπλευρη συνέπεια (επίπτωση).

Η μετρική της επίπτωσης μετρά τις συνέπειες σε έναν οργανισμό όταν οι πληροφορίες από ένα CTIP έχουν αξιοποιηθεί. Η αυτόματη εφαρμογή των πληροφοριών που παρέχονται στα CTIPs χωρίς τον γνώμονα της επίπτωσης, μπορεί να επιφέρει δυσλειτουργίες στον οργανισμό, όπως αυτές που προαναφέρθηκαν στην προηγούμενη παράγραφο. Έτσι σε ένα CTIP πρέπει επίσης να παρέχονται πληροφορίες για τις πιθανές επιπτώσεις που μπορεί να παρουσιαστούν κατά την αξιοποίησή του, δηλαδή τις παράπλευρες συνέπειες που θα μπορούσε να επιφέρει η εφαρμογή του συγκεκριμένου CTIP. Για παράδειγμα το χρονικό διάστημα αποκλεισμού μιας IP.

Κατά την παρούσα έρευνα και κατά την μελέτη του STIX2 δεν διαπιστώθηκε η ύπαρξη κάποιου πεδίου σχετικού με τις επιπτώσεις της αξιοποίησης ενός CTIP. Το εν λόγω ποιοτικό κριτήριο επομένως δεν μπορεί στην πράξη να χρησιμοποιηθεί. Παρότι αποτελεί σημαντικό κριτήριο, χρήζει περαιτέρω υποστήριξης, ίσως με επέκταση του STIX2 σχήματος.

4. ΚΑΤΑΓΡΑΦΗ ΠΗΓΩΝ CTI

Το αρχικό στάδιο της έρευνας ήταν η αναζήτηση πηγών CTI οι οποίες προσφέρουν CTIPs. Κατά τη διάρκεια, διαπιστώθηκε ότι δεν προσέφεραν όλες οι πηγές τις πληροφορίες τους στο πρότυπο STIX2. Έτσι, αποφασίστηκε η μετατροπή στο πρότυπο STIX2, όσων πηγών περιείχαν διαφορετικές μορφές CTIPs. Στην παρούσα έρευνα δεν συμπεριλήφθηκαν πηγές επί πληρωμή και πηγές που για την σύνδεση σε αυτές απαιτούσαν λειτουργικό σύστημα διαφορετικό από Windows (π.χ., πηγή που απαιτεί χρήση Linux). Στο τέλος, επιτεύχθηκε η άντληση CTIPs από τις παρακάτω 8 πηγές με διαφορετικό τρόπο και API (Application Programming Interface) για την κάθε μία. Στην ταξινόμηση και αξιολόγηση της κάθε πηγής δεν συμπεριλήφθηκαν τα SROs καθώς αποτελούν συσχετίσεις SDOs και SCOs και επομένως δεν έχουν σημασιολογική ερμηνεία (semantic meaning).

Στο παρόν κεφάλαιο, παρουσιάζεται ο συλλογισμός για την επιλογή συστήματος διαχείρισης βάσης δεδομένων (Κεφάλαιο 4.1) με σκοπό την αποθήκευση των CTIPs που θα αντληθούν από τις πηγές, οι οποίες αναφέρονται στη συνέχεια (Κεφάλαιο 4.2).

4.1. ΕΠΙΛΟΓΗ ΣΥΣΤΗΜΑΤΟΣ ΔΙΑΧΕΙΡΙΣΗΣ ΒΑΣΗΣ ΔΕΔΟΜΕΝΩΝ

Οι βάσεις δεδομένων που μπορούν να χρησιμοποιηθούν είναι είτε σχεσιακές (SQL) είτε μη σχεσιακές (NoSQL) [31]. Η τελική απόφαση ήταν η χρήση μη σχεσιακών. Ο λόγος είναι ότι οι μη σχεσιακές βάσεις δεδομένων είναι καταλληλότερες για μη δομημένα δεδομένα όπως JSON (το πρότυπο STIX2 είναι σε JSON μορφή) και επειδή αυτές οι βάσεις έχουν δυναμικά σχήματα για μη δομημένα δεδομένα [32].

Στην συνέχεια εξετάστηκαν οι μη σχεσιακές βάσεις mongoDB και Neo4J. Η πρώτη καθότι είναι ευρέως χρησιμοποιούμενη και η δεύτερη καθότι προσφέρει εικονικοποίηση.

Η εστίαση της σκέψης για την επιλογή έγινε πάνω στην συμβατότητα των JSON (και κατά συνέπεια του STIX2) δεδομένων με τη βάση και την δημιουργία CRUD queries (CREATE, READ, UPDATE, DELETE).

Η Neo4j είναι μια βάση δεδομένων γραφήματος [33]. Μια τέτοια βάση δεδομένων εστιάζει στις συσχετίσεις μεταξύ των δεδομένων κάτι που είναι ενδιαφέρον καθώς στο STIX2 σχήμα υπάρχουν πολλές συσχετίσεις. Είναι δυνατή η εισαγωγή JSON δεδομένων στην Neo4j. Η βάση αυτή χρησιμοποιεί για queries την γλώσσα Cypher για να ταιριάζει μοτίβα από κόμβους, εμπνευσμένη από την SQL. Η γλώσσα Cypher είναι πιο περίπλοκη από την SQL ωστόσο.

Η mongoDB είναι βάση NoSQL και χρησιμοποιεί JSON δεδομένα [34]. Υποστηρίζει πίνακες και εμφωλευμένα αντικείμενα (nested objects) για ευέλικτα και δυναμικά σχήματα. Είναι εύκολη στη χρήση και παρέχει δύο (2) τρόπους συσχέτισης (reference και embedded). Στα queries υπάρχει τρόπος φιλτραρίσματος και ταξινόμησης των δεδομένων καθώς τα queries είναι και αυτά JSON. Επιπρόσθετα υποστηρίζει την χρήση της γλώσσας SQL.

Η Neo4J απορρίφθηκε καθότι αύξανε το επεξεργαστικό κόστος με την έννοια της αποθήκευσης δεδομένων και στην παρούσα ανάλυση των πηγών δεν θα προσέφερε επιπρόσθετο όφελος η αξιοποίηση των συσχετίσεων. Η τελική επιλογή έκλεισε στην mongoDB λόγω της μεγάλης συμβατότητας με JSON δεδομένα, την υποστήριξη των εμφωλευμένων αντικειμένων, την εύκολη εισαγωγή JSON και το απλό φιλτράρισμα και αναζήτηση μέσω SQL και JSON ερωτημάτων.

4.2. ΠΗΓΕΣ CTI

4.2.1. MISP

Η MISP (Malware Information Sharing Platform) [35] είναι μια πλατφόρμα πληροφοριών κυβερνοαπειλών ανοιχτού κώδικα που συντηρείται από τον οργανισμό CIRCL. Η σύνδεση στη πλατφόρμα πραγματοποιείται με τη χρήση εικονικής μηχανής ή με χρήση του Docker. Τα CTIPs της MISP προσφέρονται με REST API. Τέλος, αναφέρεται ότι η MISP προσφέρει δεδομένα σε μορφή STIX2. Η σύνδεσή στην πηγή αυτή έγινε μέσω Docker και την γλώσσα Python.

4.2.2. ANOMALI

Η ANOMALI είναι μια Αμερικάνικη εταιρεία κυβερνοασφάλειας γνωστή για την πλατφόρμα threat intelligence and analysis. Τα προϊόντα που προσφέρει είναι τα: ThreatStream, Anomali Enterprise, STAXX, Limo. Το Limo είναι μια υπηρεσία της Anomali για χρήστες που ξεκινάνε την ενασχόλησή τους με CTI [36] και είναι συμβατή με το STIX2 σχήμα. Τα CTIPs της Anomali προσφέρονται μέσω ενός TAXII server. Η σύνδεση στη πηγή και η άντληση των CTIPs έγινε με τη βιβλιοθήκη της python taxii2client.

4.2.3. MITRE

Η MITRE ATT&CK είναι μια παγκόσμια προσβάσιμη βάση γνώσεων για αντίπαλες τακτικές και τεχνικές που βασίζονται σε πραγματικές παρατηρήσεις απειλών για την ασφάλεια στον κυβερνοχώρο [37]. Αυτά εμφανίζονται σε πίνακες που τακτοποιούνται κατά τα στάδια της επίθεσης, από την αρχική πρόσβαση στο σύστημα έως τη κλοπή δεδομένων ή τον έλεγχο του συστήματος. Τα CTIPs της MITRE προσφέρονται σε STIX2 μέσω ενός TAXII server. Η σύνδεση στη πηγή και η άντληση των CTIPs έγινε με τη βιβλιοθήκη της python taxii2client.

4.2.4. BLUELIV

Το Blueliv's Threat Exchange Network (ή BLUELIV) προσφέρει την δυνατότητα σε διάφορους χρήστες της κοινότητας να αναρτήσουν πληροφορίες σχετικές με απειλές που τις ονομάζει sparks [38]. Η BLUELIV προσφέρει τα CTIPs της σε CSV μορφή, μέσω REST API. Η σύνδεση στη πηγή έγινε μέσω REST API και τη γλώσσα Python. Τα προσφερόμενα CTIPs μετατράπηκαν σε JSON και έπειτα στο πρότυπο STIX2.

4.2.5. OTX

Το Open Threat Exchange (OTX) AlienVault είναι μια πλατφόρμα απειλών που επιτρέπει στους ερευνητές ασφάλειας και τους παραγωγούς δεδομένων απειλών να μοιράζονται έρευνα και να αναζητούν νέες απειλές [39]. Το OTX παρέχει ανοιχτή πρόσβαση για όλους επιτρέποντάς τη συνεργασία με μια παγκόσμια κοινότητα ερευνητών απειλών και επαγγελματιών ασφαλείας. Αυτή η ανοιχτή κοινότητα επιτρέπει τη συλλογική έρευνα επιτρέποντας σε όλους στην OTX να μοιράζονται ενεργά πληροφορίες, τάσεις και τεχνικές απειλών. Η OTX προσφέρει τα δεδομένα της σε JSON μορφή, μέσω REST API. Η σύνδεση στη πηγή έγινε μέσω REST API, με Python, και τα δεδομένα της μετατράπηκαν από JSON σε STIX2.

4.2.6. URLHAUS

Το URLHAUS είναι ένα έργο (project) από το abuse.ch [40] με στόχο την κοινή χρήση κακόβουλων διευθύνσεων URL που χρησιμοποιούνται για τη διανομή κακόβουλου λογισμικού. Σκοπός του URLHAUS είναι η συλλογή, παρακολούθηση και διαμοιρασμός κακόβουλων διευθύνσεων URL βοηθώντας τους διαχειριστές δικτύου και τους αναλυτές ασφάλειας να προστατεύσουν το δίκτυο και τους πελάτες τους, από απειλές στον κυβερνοχώρο. Η σύνδεση στη πηγή έγινε μέσω REST API με Python. Τα CTIPs της πηγής ήταν σε μορφή CSV, τα οποία μετατράπηκαν σε JSON και στην συνέχεια σε STIX2.

4.2.7. PULSEDIVE

Η PULSEDIVE προσφέρει μια δωρεάν πλατφόρμα πληροφοριών για τις κυβερνοαπειλές και προϊόντα δεδομένων για να βοηθήσει οποιαδήποτε ομάδα ασφαλείας να εξορθολογήσει την έρευνα, σχετικά με τις κυβερνοαπειλές [41]. Η σύνδεση στη πηγή έγινε μέσω REST API με Python. Τα CTIPs ήταν σε μορφή CSV, μετατράπηκαν σε JSON και έπειτα σε STIX2.

4.2.8. MRLOOQUER

Το MRLOOQUER παρέχει μια λύση για τον προσδιορισμό του επιπέδου έκθεσης σε επιθέσεις και την υποστήριξη στην ακριβή διαχείριση του κινδύνου [42]. Τα προσφερόμενα CTIPs του αφορούν dual stack IP διευθύνσεις (IPv4 και IPv6) οπότε καλύπτει ολόκληρο το διαδίκτυο. Το MRLOOQUER παρέχει CTIPs σε CSV μορφή. Αναφέρει, ωστόσο, ότι αργότερα θα υπάρχει ξεχωριστό κομμάτι για CTIPs που είναι στο σχήμα STIX2. Τα CTIPs που προσφέρει βρίσκονται στην ιστοσελίδα της πηγής και είναι προσβάσιμα με GET requests. Η άντληση των CTIPs έγινε με τη βιβλιοθήκη requests [43] της Python. Τα CTIPs μετέπειτα, μετατράπηκαν σε JSON και τέλος σε STIX2.

Ο Πίνακας I παρουσιάζει όλες τις ανωτέρω πληροφορίες ανά πηγή. Συγκεκριμένα, δείχνει ανά πηγή τον τρόπο σύνδεσης που πραγματοποιήθηκε, τον τρόπο άντλησης των CTIPs, την μορφή των προσφερόμενων CTIPs και αν αυτά ακολουθούν κάποιο σχήμα και ποιο.

Πίνακας I: Σύνδεση με CTI πηγές.

Πηγή	Τρόπος σύνδεσης	Τρόπος άντλησης CTIPs	Μορφή προσφερόμενων CTIPs	Ακολουθεί συγκεκριμένο σχήμα;
MISP	url,api key,library,docker	όλα μαζί	CSV	STIX2
URLHAUS	url,get	όλα μαζί,ανά χρονολογία	CSV	όχι
BLUELIV	token,url,get	ανά tags	CSV	όχι
PULSEDIVE	api key,url,get	ανά id του CTIP	CSV	όχι
MRLOOQUER	url,get	ανά τύπο CTIP	CSV	όχι (αναφέρει "STIX soon")
OTX	api key,url,get	όλα μαζί	JSON	όχι
ANOMALI	username,password,library	ανά collection	CSV	STIX2
MITRE	username,password,library	ανά collection	CSV	STIX2

5. ΔΙΕΠΑΦΕΣ ΜΕΤΑΤΡΟΠΗΣ

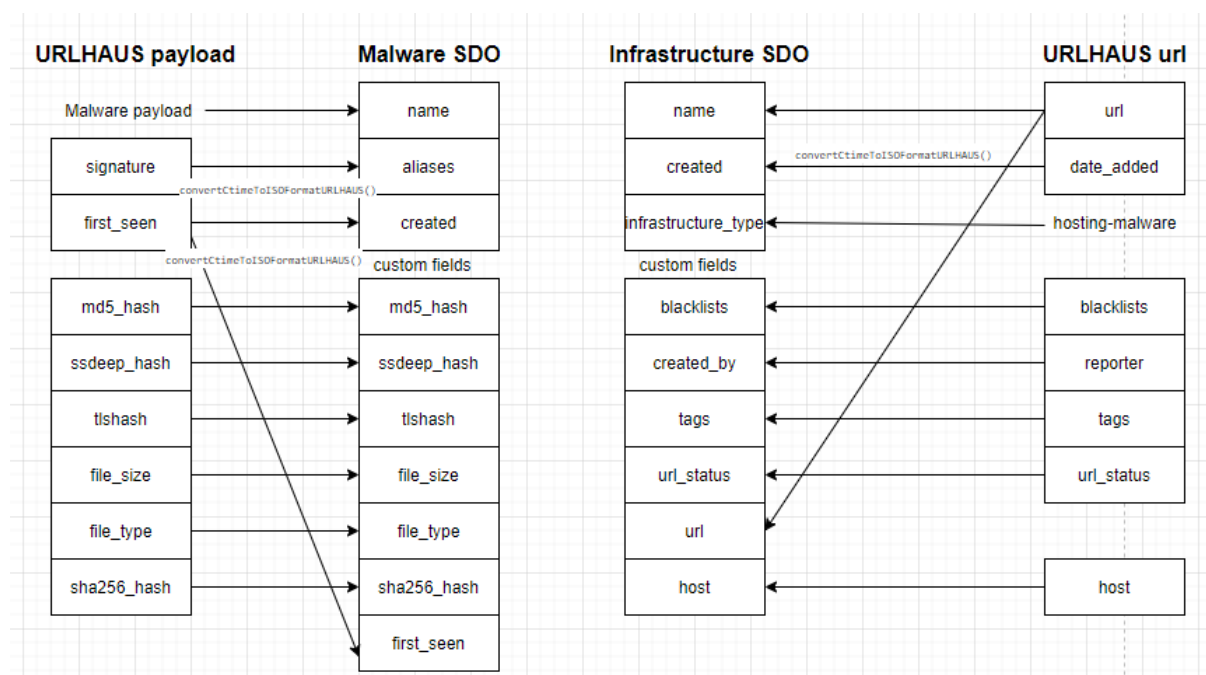
Στο κεφάλαιο αυτό αναλύεται η μετατροπή CTIPs από non-STIX2 σε STIX2, καθώς διαπιστώθηκε ότι οι διάφορες πηγές δεν ακολουθούν το STIX2. Η εν λόγω μετατροπή επιτρέπει την επεξεργασία των CTIPs με ενιαίο τρόπο και βοηθάει στην ομοιομορφία των αποτελεσμάτων της αξιολόγησης και ταξινόμησης των πηγών.

Για την μετατροπή χρησιμοποιήθηκε η βιβλιοθήκη “stix2” της python [44]. Η βιβλιοθήκη αυτή επιτρέπει την επεξεργασία (ανάγνωση και τροποποίηση) υπαρχόντων CTIPs εκφρασμένων σε STIX2 αλλά και την δημιουργία νέων.

Σε γενικά πλαίσια, αρχικά λαμβάνονται non-STIX2 CTIPs από μια πηγή με χρήση κατάλληλης διεπαφής με την εν λόγω πηγή. Μετέπειτα τα εν λόγω CTIPs αναγιγνώσκονται (parse) και μετατρέπονται σε STIX2 SDOs. Για παράδειγμα, αν μια πηγή προσφέρει non-STIX2 CTIPs που περιγράφουν malware σε CSV μορφή αυτά γίνονται Malware SDOs. Η εν λόγω μετατροπή περιλαμβάνει επίσης την αντιστοίχιση των πεδίων των non-STIX2 CTIPs στα κατάλληλα STIX2 SDOs πεδία. Τέλος δημιουργούνται τα κατάλληλα SROs ώστε να δημιουργηθούν και οι κατάλληλες συσχετίσεις μεταξύ SDOs.

5.1. ΜΕΤΑΤΡΟΠΗ URLHAUS

Η URLHAUS προσφέρει δύο ειδών CTIPs σε CSV μορφή. Το πρώτο αφορά URLs και το δεύτερο κακόβουλα αρχεία (malicious payloads). Τα URLs μετατρέπονται σε Infrastructure SDOs και τα malicious payloads σε Malware SDOs. Η εν λόγω μετατροπή καθώς και η αντιστοίχιση των σχετικών πεδίων φαίνονται στην Εικόνα 5.



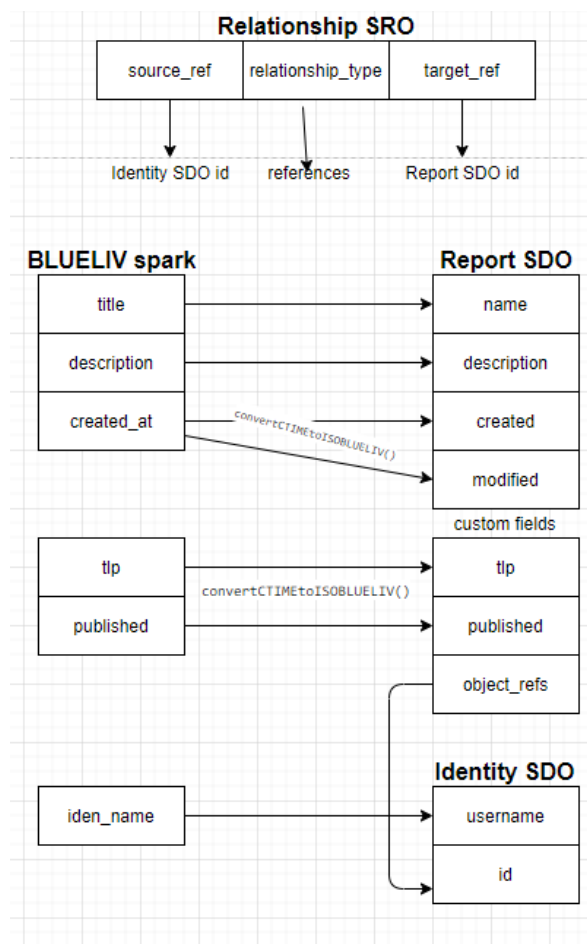
Εικόνα 5: Μετατροπή των CTIPs της URLHAUS σε STIX2.

Η URLHAUS συσχετίζει το κάθε URL με ένα malicious payload. Η συσχέτιση αυτή επικοινωνεί το γεγονός ότι ένα URL διατηρεί ένα malicious payload. Σε STIX2 έννοια αυτό οδηγεί σε ένα Relationship SRO με τύπο σχέσης «Infrastructure-hosted-Malware». Η εν λόγω συσχέτιση ωστόσο δεν μπόρεσε να πραγματοποιηθεί για τον λόγο ότι ο απομακρυσμένος διακομιστής του URLHAUS μπλοκάρει τις αιτήσεις για την συσχέτιση των payloads με τα URLs. Σημειώνεται ότι το εν λόγω δεν

επηρεάζει τα αποτελέσματα της έρευνας καθώς τα Relationship SRO αυτά καθ' αυτά δεν έχουν εννοιολογική σημασία (semantic meaning) και περαιτέρω πεδία.

5.2. ΜΕΤΑΤΡΟΠΗ BLUELIV

Η BLUELIV προσφέρει ενός είδους CTIPs σε CSV μορφή. Τα CTIPs της, που ονομάζονται sparks, περιέχουν αναφορές για κυβερνοεπιθέσεις, οι οποίες δημοσιεύονται από οργανισμούς. Με αυτήν την λογική, τα sparks μετατρέπονται σε Report και Identity SDOs. Η εν λόγω μετατροπή καθώς και η αντιστοίχιση των σχετικών πεδίων φαίνονται στην Εικόνα 6.

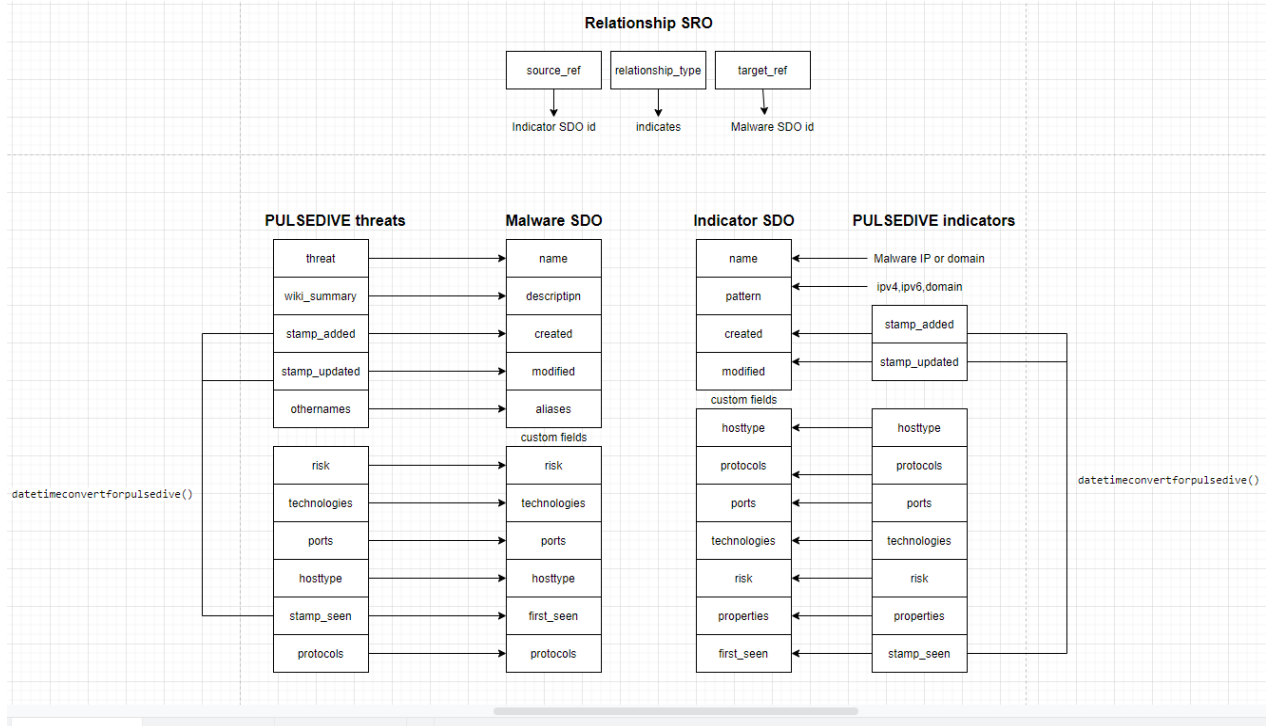


Εικόνα 6: Μετατροπή των CTIPs της BLUELIV σε STIX2.

Η BLUELIV συσχετίζει το κάθε report με έναν οργανισμό ή επαγγελματία που το αναφέρει. Η συσχέτιση αυτή επικοινωνεί το γεγονός ότι ένας οργανισμός αναφέρει ένα report. Σε STIX2 έννοια αυτό οδηγεί σε ένα Relationship SRO με τύπο σχέσης «Identity-references-Report».

5.3. ΜΕΤΑΤΡΟΠΗ PULSEDIVE

Η PULSEDIVE προσφέρει δύο ειδών CTIPs σε JSON μορφή. Το πρώτο αφορά indicators και το δεύτερο απειλές (threats). Τα indicators μετατρέπονται σε Indicator SDOs και τα threats σε Malware SDOs. Η εν λόγω μετατροπή καθώς και η αντιστοίχιση των σχετικών πεδίων φαίνονται στην Εικόνα 7.

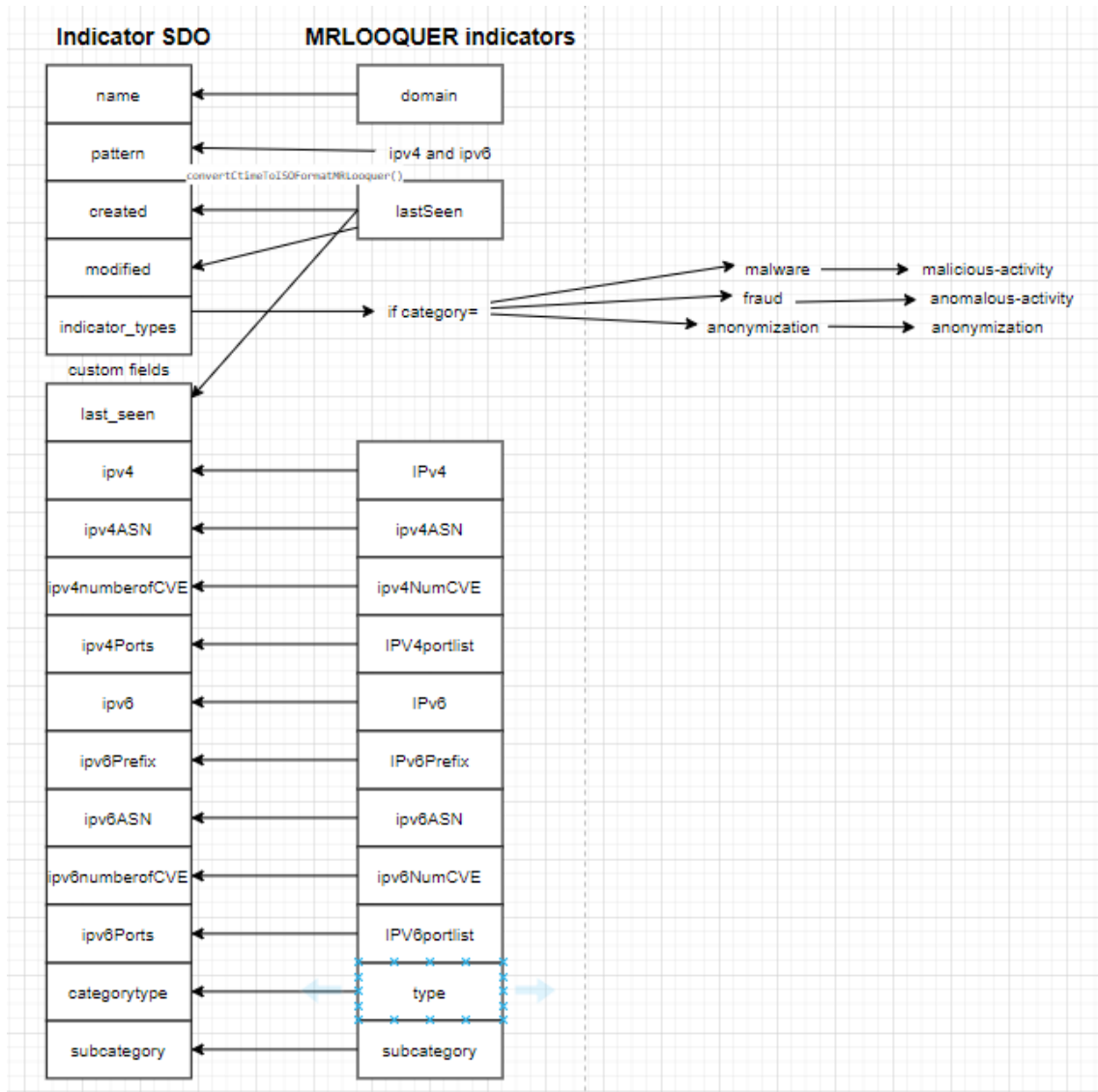


Εικόνα 7: Μετατροπή των CTIPs της PULSEDIVE σε STIX2.

Η PULSEDIVE συσχετίζει το κάθε threat με πολλαπλούς indicators. Η συσχέτιση αυτή επικοινωνεί το γεγονός ότι ένας indicator υποδείχνει ένα συγκεκριμένο threat. Σε STIX2 έννοια αυτό οδηγεί σε ένα Relationship SRO με τύπο σχέσης «Indicator-indicates-Malware».

5.4. ΜΕΤΑΤΡΟΠΗ MRLOOQUER

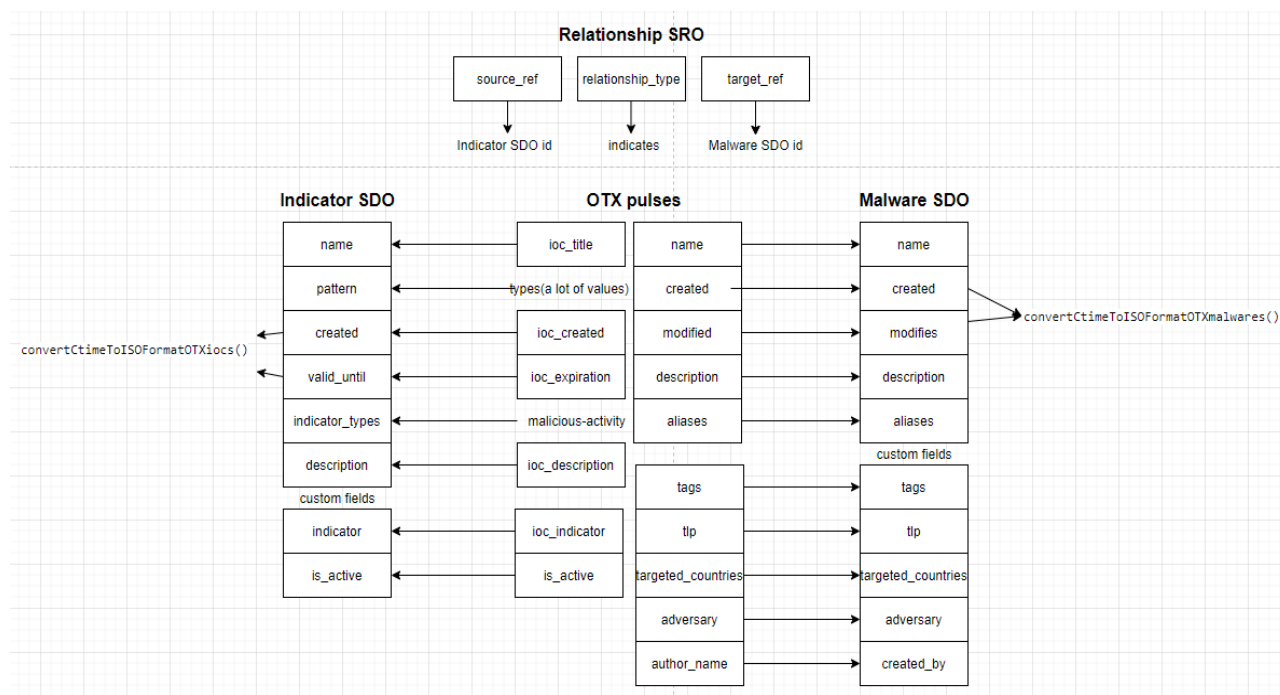
Η BLUELIV προσφέρει ενός είδους CTIPs σε CSV μορφή. Τα CTIPs της περιέχουν μόνο indicators. Με αυτήν την λογική, τα indicators μετατρέπονται σε Indicator SDOs. Η εν λόγω μετατροπή καθώς και η αντιστοίχιση των σχετικών πεδίων φαίνονται στην Εικόνα 8.



Εικόνα 8: Μετατροπή των CTIPs της MRLOOQUER σε STIX2.

5.5. ΜΕΤΑΤΡΟΠΗ OTX

Η OTX προσφέρει ενός είδους CTIPs σε JSON μορφή. Τα CTIPs της, που τα ονομάζει παλμούς (pulses) περιέχουν κυβερνοαπειλές και πολλαπλούς συνδεδεμένους indicators για την κάθε κυβερνοαπειλή. Με αυτήν την λογική, οι κυβερνοαπειλές μετατρέπονται σε Malware SDOs και ο κάθε συνδεδεμένος indicator για κάθε κυβερνοαπειλή, ξεχωριστά σε Indicator SDO. Η εν λόγω μετατροπή καθώς και η αντιστοίχιση των σχετικών πεδίων φαίνονται στην Εικόνα 9.



Εικόνα 9: Μετατροπή των CTIPs της OTX σε STIX2.

Η OTX συσχετίζει την κάθε κυβερνοαπειλή με πολλαπλούς indicators. Η συσχέτιση αυτή επικοινωνεί το γεγονός ότι ένας indicator υποδείχνει μια συγκεκριμένη κυβερνοαπειλή. Σε STIX2 έννοια αυτό οδηγεί σε ένα Relationship SRO με τύπο σχέσης «Indicator-indicates-Malware».

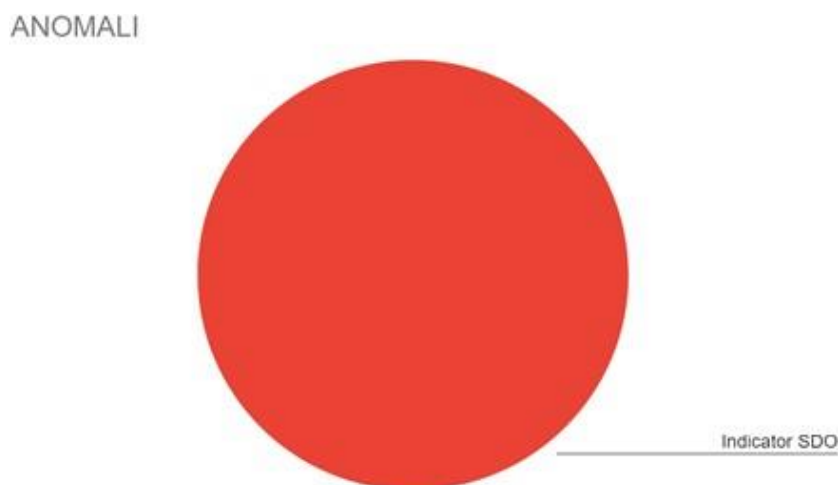
6. ΤΑΞΙΝΟΜΗΣΗ ΑΝΑΚΤΗΘΕΝΤΟΣ ΠΕΡΙΕΧΟΜΕΝΟΥ

Σε αυτή την ενότητα το περιεχόμενο της κάθε πηγής, ήτοι τα CTIPs που διαθέτει, ταξινομήθηκε με βάση τα αντικείμενα STIX2 SDO και τα στάδια της KC.

Για την ταξινόμηση χρησιμοποιήθηκαν τα τελικά CTIPs STIX2 που προέκυψαν μετά την μετατροπή όπως αυτή περιγράφεται στο Κεφάλαιο 5. Η ταξινόμηση πραγματοποιήθηκε με κατάλληλα ερωτήματα (queries) την mongoDB που βρίσκονται αποθηκευμένα τα CTIPs STIX2. Το κάθε ερώτημα απαντούσε στο «πόσα συγκεκριμένα STIX2 SDO» ή στο «πόσα CTIPs περιείχαν KC στάδια και ποια».

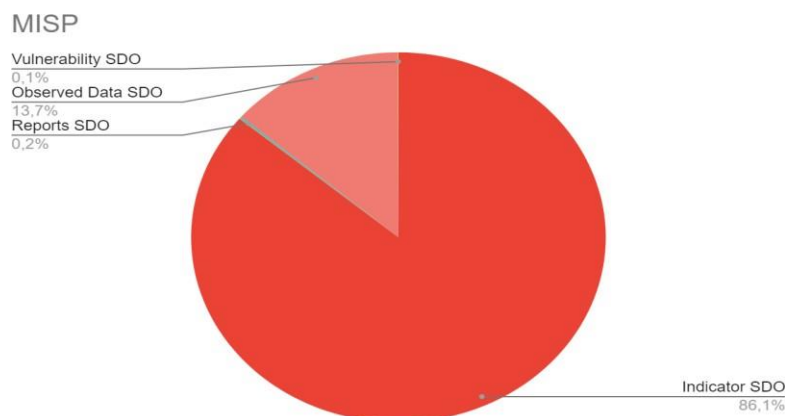
6.1. ΤΑΞΙΝΟΜΗΣΗ ΠΕΡΙΕΧΟΜΕΝΟΥ ΜΕ ΒΑΣΗ STIX2 SDO

Η ANOMALI, με βάση το Γράφημα 1, αποτελείται από Indicator SDOs μόνο.



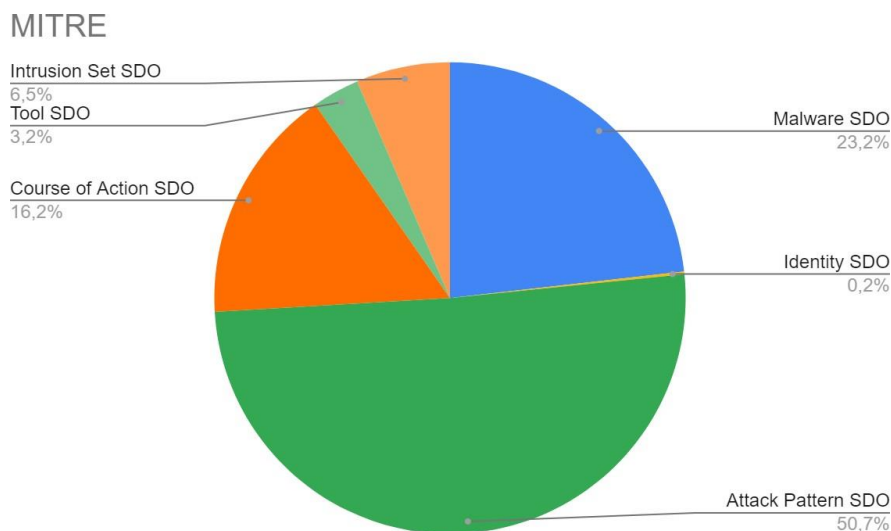
Γράφημα 1: SDOs που προσφέρει η ANOMALI.

Η MISP, με βάση το Γράφημα 2, περιέχει διαφορετικά αντικείμενα STIX2. Από το γράφημα βλέπουμε πως στο μεγαλύτερο ποσοστό της περιέχει Indicator SDOs. Επιπρόσθετα, διαθέτει κάποια ποσοστά από Vulnerability, Observed Data και Report SDO.



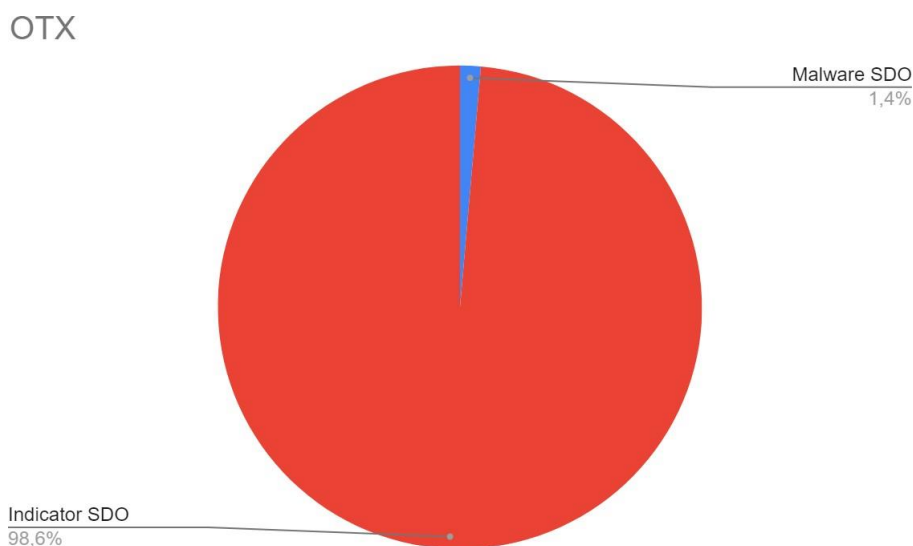
Γράφημα 2: SDOs που προσφέρει η MISP.

Η MITRE, με βάση το Γράφημα 3, περιέχει αρκετά διαφορετικά αντικείμενα STIX2. Η συγκεκριμένη πηγή περιέχει κατά πλειοψηφία Attack Pattern SDOs, ενώ περιέχει και ποσοστά για Malware, Intrusion Set, Course of Action, Identity και Tool SDO.



Γράφημα 3: SDOs που προσφέρει η MITRE.

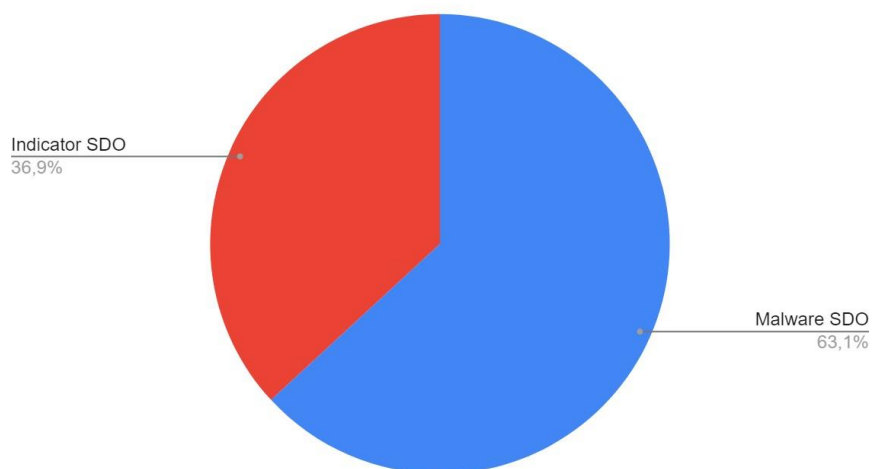
Η OTX, με βάση το Γράφημα 4, περιέχει σε μεγάλη πλειοψηφία Indicator SDO, ενώ υπάρχει και ένα πολύ μικρό ποσοστό από Malware SDO.



Γράφημα 4: SDOs που προσφέρει η OTX.

Η PULSEDIVE, με βάση το Γράφημα 5, αποτελείται από τα Malware SDO κατά 63,1% και Indicator SDO κατά 36,9%.

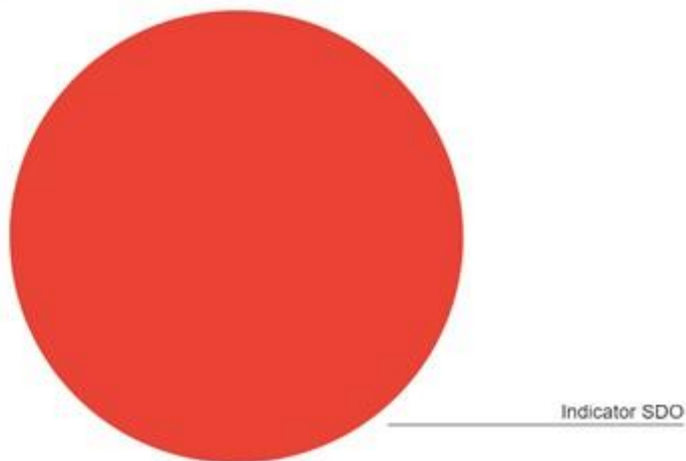
PULSEDIVE



Γράφημα 5: SDOs που προσφέρει η PULSEDIVE.

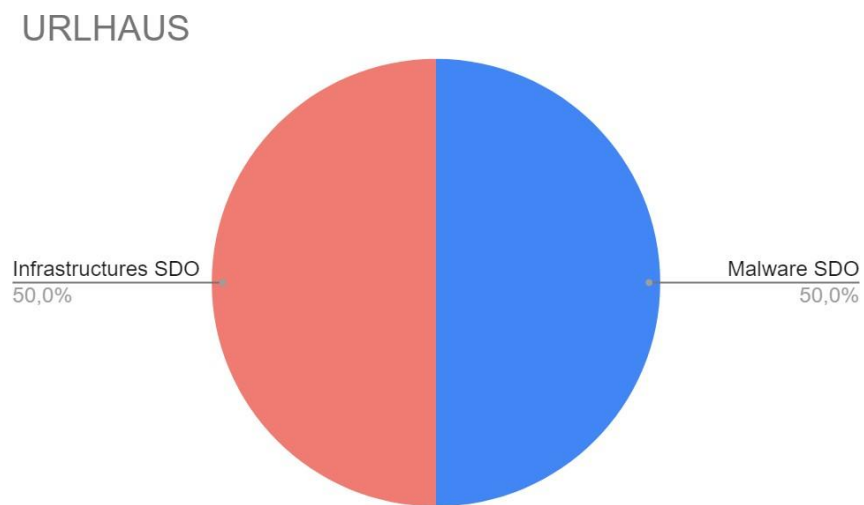
6. Η MRLOOQUER αποτελείται εξολοκλήρου από Indicator SDO, όπως φαίνεται στο Γράφημα

MRLOOQUER



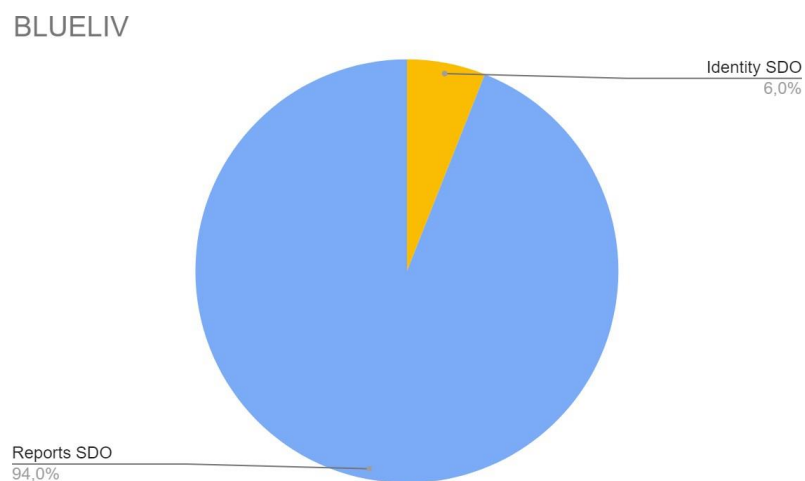
Γράφημα 6: SDOs που προσφέρει η MRLOOQUER.

Η URLHAUS έχει ισάξιο πλήθος από Malware και Indicator SDO, όπως αυτό φαίνεται στο Γράφημα 7.



Γράφημα 7: SDOs που προσφέρει η URLHAUS.

Η BLUELIV περιέχει Report SDO σε ποσοστό 94%, αλλά υπάρχει και ένα μικρό ποσοστό σε Identity SDO όπως φαίνεται στο Γράφημα 8.



Γράφημα 8: SDOs που προσφέρει η BLUELIV.

Ο Πίνακας II συνοψίζει τα SDOs που εντοπίστηκαν ανά πηγή.

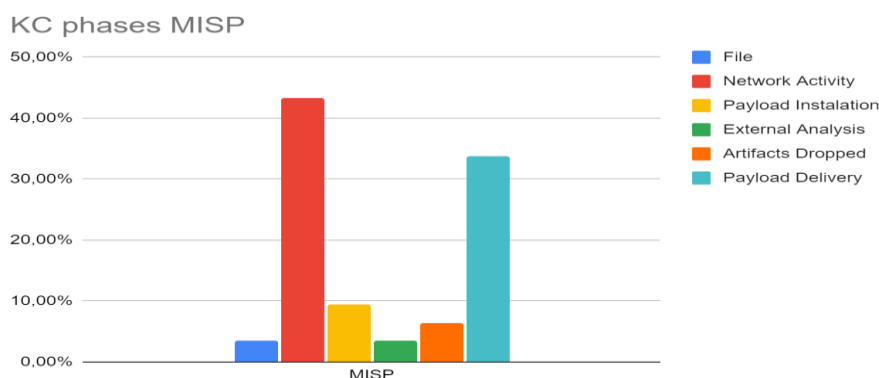
Πίνακας II: Είδη αντικείμενων STIX2 που περιέχονται σε κάθε πηγή.

Πηγές	Malware SDO	Indicator SDO	Identity SDO	Attack Pattern	Course of Action	Reports SDO	Infrastructures	Observed Data	Vulnerability SDO	Tool SDO	Intrusion Set SDO
MISP		✓	✓			✓		✓	✓		
URLHAUS	✓						✓				
BLUELIV			✓			✓					
PULSEDIVE	✓	✓									
MRLOOQUER		✓									
OTX	✓	✓									
ANOMALI		✓									
MITRE	✓		✓	✓	✓					✓	✓

6.2. ΤΑΞΙΝΟΜΗΣΗ ΠΕΡΙΕΧΟΜΕΝΟΥ ΜΕ ΒΑΣΗ ΤΑ ΣΤΑΔΙΑ KILL CHAIN

Οι μοναδικές πηγές που περιείχαν πεδία σχετικά με τα στάδια της KC στα CTIPs τους ήταν η MITRE και η MISP.

Ξεκινώντας από την MISP, αναφέρεται πως από τα 82604 CTIPs, τα 68850 της περιείχαν στάδια KC, ήτοι ένα μεγάλο ποσοστό της τάξης των 83,34%. Το εν λόγω φαίνεται στο Γράφημα 9. Επίσης στο γράφημα παρουσιάζονται τα ποσοστά των CTIPs ανά στάδιο της KC, με τα περισσότερα να αφορούν τα στάδια Network Activity και Payload Delivery.



Γράφημα 9: CTIPs της MISP ανά KC στάδιο.

Στη MITRE αναφέρεται πως τα 883 CTIPs εκ των 12824 που προσφέρει αφορούν KC στάδια, ήτοι ένα ποσοστό της τάξης του 6.88%. Είναι ένα μικρό ποσοστό συγκριτικά με αυτό της MISP, αλλά είναι σημαντικό να αναφέρουμε ότι η MITRE σε αυτά τα 883 CTIPs της περιείχε 88 διαφορετικά KC στάδια. Πολύ μεγαλύτερος αριθμός από τα 6 στάδια της MISP. Για τον λόγο αυτό ήταν δύσκολο να δημιουργηθεί κάποιο γράφημα.

7. ΠΟΙΟΤΙΚΗ ΑΞΙΟΛΟΓΗΣΗ ΤΩΝ ΠΗΓΩΝ CTI

Στο συγκεκριμένο κεφάλαιο αξιολογούνται τα CTIPs βάση των ποιοτικών κριτηρίων της φρεσκάδας και της πληρότητας. Επιπρόσθετα, τα CTIPs αξιολογήθηκαν βάση του πλήθους των CoAs και των CVE, CPE, CAPEC που περιέχουν. Τα τελευταία μπορούν να χρησιμοποιηθούν στην εκτίμηση και διαχείριση ρίσκου και επομένως κρίνεται σημαντική μια τέτοια αξιολόγηση. Τα αποτελέσματα συνοψίζονται στους Πίνακες III και IV, βάση των οποίων προέκυψαν τα γραφήματα που αναλύονται στα Κεφάλαια 7.1 έως 7.4.

Στον Πίνακα III βλέπουμε σε ποσότητες αλλά και σε ποσοστά τα αποτελέσματα της εφαρμογής των δύο ποιοτικών κριτηρίων, δηλαδή της φρεσκάδας και της πληρότητας. Η αξιολόγηση έγινε πριν αλλά και μετά την μετατροπή από non-STIX2 CTIPs σε STIX2 CTIPs. Αυτό επιβεβαιώνει ότι η μετατροπή πραγματοποιήθηκε επιτυχώς.

Πίνακας III: Ανάλυση πηγών με βάση τα ποιοτικά κριτήρια φρεσκάδας και πληρότητας.

Πηγές	Φρεσκάδα	Πληρότητα
MISP	CTIPS σύνολο: 82604 2021 CTIPS: 2480 (3%) 2020 CTIPS: 1612 (1,95%) 2019 CTIPS: 456 (0,55%) 2018 CTIPS: 2800 (3,38%) 2017 CTIPS: 937 (1,13%) 2016 CTIPS: 8974 (10,86%) 2015 CTIPS: 47971 (58,07%) 2014 CTIPS: 17373 (21,03%) 2013 CTIPS: 1 (0,001%)	indicator: 60% των πεδίων βασισμένα στο σχήμα του STIX2 Observed Data: 85,71% των πεδίων βασισμένα στο σχήμα του STIX2 Vulnerabilities: 75% των πεδίων βασισμένα στο σχήμα του STIX2 Reports: 85,71% των πεδίων βασισμένα στο σχήμα του STIX2 Identities: 50% των πεδίων βασισμένα στο σχήμα του STIX2
URLHAUS	CTIPS σύνολο: 2000 2021 CTIPS :2000 (100%) και στην JSON μορφή και έπειτα από μετατροπή σε stix2	infrastructures: 37,5% των πεδίων βασισμένα στο σχήμα του STIX2 Malwares: 40% των πεδίων βασισμένα στο σχήμα του STIX2
BLUELIV	Σε JSON: 63 CTIPS 2021 CTIPS: 63 (100%) Σε STIX2: 130 CTIPS 2021 CTIPS 130(100%)	Reports: 100% των πεδίων βασισμένα στο σχήμα του STIX2 Identities: 37,5% των πεδίων βασισμένα στο σχήμα του STIX2
PULSEDIVE	Σε JSON: 236 CTIPS 2018 CTIPS: 95 (40,26%) 2017 CTIPS: 141 (59,74%) Σε STIX2: 130 CTIPS 2021 CTIPS 230(49,35%) 2018 CTIPS: 95 (20,38%) 2017 CTIPS: 141 (30,25%)	indicator: 70% των πεδίων βασισμένα στο σχήμα του STIX2 Malwares: 46,66% των πεδίων βασισμένα στο σχήμα του STIX2
MRLOOQUER	Σε JSON: 1694 CTIPS 2021 CTIPS: 1694 (100%) Σε STIX2: 1581 CTIPS 2021 CTIPS 1581(100%)	indicator: 80% των πεδίων βασισμένα στο σχήμα του STIX2
OTX	Σε JSON: 340 CTIPS 2021 CTIPS: 104 (30,58%)	indicator: 90% των πεδίων βασισμένα στο σχήμα του STIX2

	2020 CTIPS: 236 (69,42%) Σε STIX2: 50398 CTIPS 2021 CTIPS: 32205 (63,9%) 2020 CTIPS: 18193 (36,1%)	Malwares: 40% των πεδίων βασισμένα στο σχήμα του STIX2
ANOMALI	CTIPS σύνολο: 7181 2020 CTIPS: 1994 (18,28%) 2019 CTIPS: 1313 (22,05%) 2018 CTIPS: 139 (1,93%) 2017 CTIPS: 456 (6,35%) 2016 CTIPS: 3279 (45,66%)	Indicator: 60% των πεδίων βασισμένα στο σχήμα του STIX2
MITRE	CTIPS σύνολο: 12824 2021 CTIPS: 120 (0,93%) 2020 CTIPS: 4686 (36,54%) 2019 CTIPS: 2828 (22,05%) 2018 CTIPS: 2555 (19,92%) 2017 CTIPS: 2635 (20,54%)	Course of action: 100% των πεδίων βασισμένα στο σχήμα του STIX2 Intrusion sets: 45,45% των πεδίων βασισμένα στο σχήμα του STIX2 Tools: 50% των πεδίων βασισμένα στο σχήμα του STIX2 Attack patterns: 83,33% των πεδίων βασισμένα στο σχήμα του STIX2 Identities: 50% των πεδίων βασισμένα στο σχήμα του STIX2 Malwares: 40% των πεδίων βασισμένα στο σχήμα του STIX2

Στον Πίνακα IV βλέπουμε σε ποσότητες αλλά και σε ποσοστά τα αποτελέσματα ανάλυσης βάση CoA, CVE,CPE και CAPEC. Παρόμοια, η αξιολόγηση έγινε πριν, αλλά και μετά την μετατροπή από non-STIX2 CTIPs σε STIX2 CTIPs έτσι ώστε να επιβεβαιωθεί η επιτυχία της εν λόγω μετατροπής.

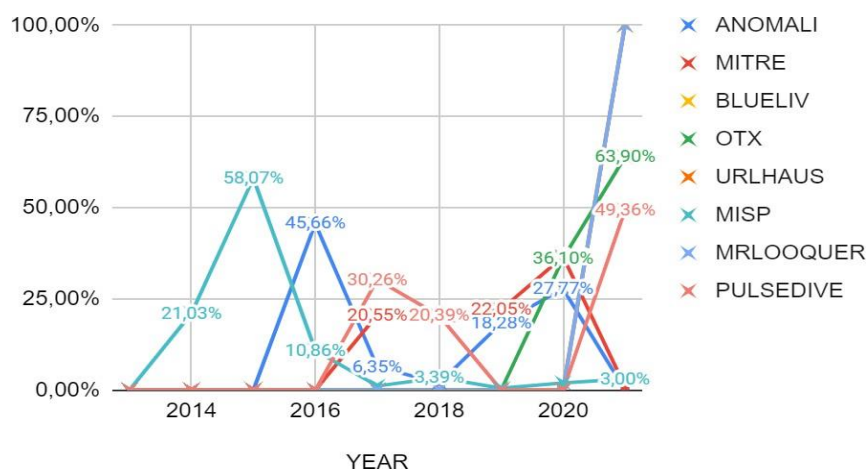
Πίνακας IV: Ανάλυση πηγών με βάση Course of Action και CVE,CPE,CAPEC

Πηγές	Course of Action	CVE,CPE,CAPEC
MISP	NONE	52 στα 82604 έγγραφα (0,06%) περιείχαν CVE's
URLHAUS	NONE	NONE
BLUELIV	NONE	σε JSON: 14 στα 63 έγγραφα (22,22%) περιείχαν CVE'S σε STIX2: 14 στα 130 (10,76%) περιείχαν CVE'S
PULSEDIVE	NONE	σε JSON: 16 στα 236 έγγραφα (6,7%) περιείχαν CVE'S σε STIX2: 1 στα 466 (0,21%) περιείχαν CVE'S
MRLOOQUER	NONE	σε JSON: 95 στα 1694 έγγραφα (5,6%)

		περιείχαν CVE'S σε STIX2: 94 στα 1581 (5,94%) περιείχαν CVE'S
OTX	NONE	σε JSON: 19 στα 340 έγγραφα (5,58%) περιείχαν CVE'S σε STIX2: 273 στα 50398 (0,54%) περιείχαν CVE'S
ANOMALI	NONE	NONE
MITRE	330 στα 12824 έγγραφα (2,57%) περιείχαν courses of actions	86 στα 12824 έγγραφα (1,06%) περιείχαν CVE's 151 στα 12824 έγγραφα (1,17%) περιείχαν CAPEC's"

7.1. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΗ ΦΡΕΣΚΑΔΑ

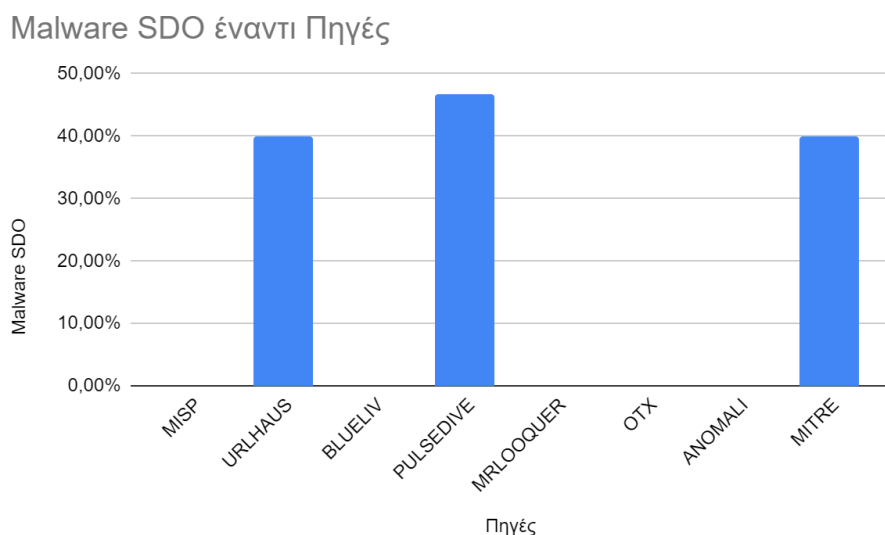
Στο παρακάτω Γράφημα 10 απεικονίζεται το πλήθος των CTIPs της κάθε πηγής, ανά έτος. Με βάση το γράφημα, μπορούμε να συμπεράνουμε πως η πηγή MISP περιέχει τα περισσότερα δεδομένα της το έτος 2015 και έπειτα παρατηρείται χαμηλή συχνότητα ανανέωσης. Το περιεχόμενο του αποθετηρίου της ANOMALI παρουσιάζει μια ποσοτική αύξηση το έτος 2016, έπειτα μια μείωση, ενώ έχουμε μια σημαντική αύξηση από το 2019 και μετά. Η πηγή OTX εμφανίζεται να περιέχει τα πιο φρέσκα CTIPs καθώς το δείγμα μας περιέχει μόνο CTIPs του έτους 2020 και 2021, παρουσιάζοντας ακόμα μεγαλύτερη άνοδο στο τελευταίο έτος. Η δραστηριότητα της MITRE ξεκινάει το έτος 2016, έχοντας μια συνεχόμενη ανοδική πορεία μέχρι το 2020. Το 2021 παρουσιάζει σημαντική πτώση. Οι πηγές BLUELIV και URLHAUS και MRLOOQUER παρουσιάζουν σημαντική φρεσκάδα καθώς όλα τους τα δεδομένα προέρχονται από το έτος 2021. Η PULSEDIVE δείχνει μια ενεργή συχνότητα δημοσίευσης CTIPs από το έτος 2016 μέχρι το 2018, μια παύση μεταξύ 2019 και 2020 και τέλος αυξάνεται ξανά η δραστηριότητά της το έτος 2021.



Γράφημα 10: Φρεσκάδα για κάθε πηγή.

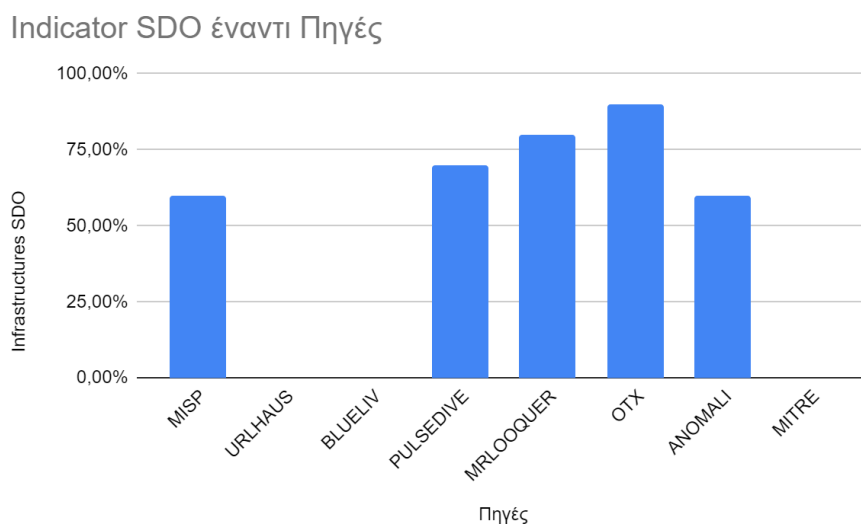
7.2. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΗ ΠΛΗΡΟΤΗΤΑ

Το Malware SDO χρησιμοποιείται για να περιγράψει κακόβουλο κώδικα που εισάγεται σε ένα σύστημα, συνήθως κρυφά, με σκοπό τη διακύβευση της εμπιστευτικότητας, της ακεραιότητας και της διαθεσιμότητας των πόρων του συστήματος. Διαπιστώθηκε ότι Malware SDOs προσφέρονται από την PULSEDIVE, MITRE και URLHAUS. Και οι τρεις πηγές φαίνεται πως προσφέρουν Malware SDOs με σχετικά ίδια ποσοστά πληρότητας περίπου της τάξης του 50%, όπως φαίνεται στο Γράφημα 11.



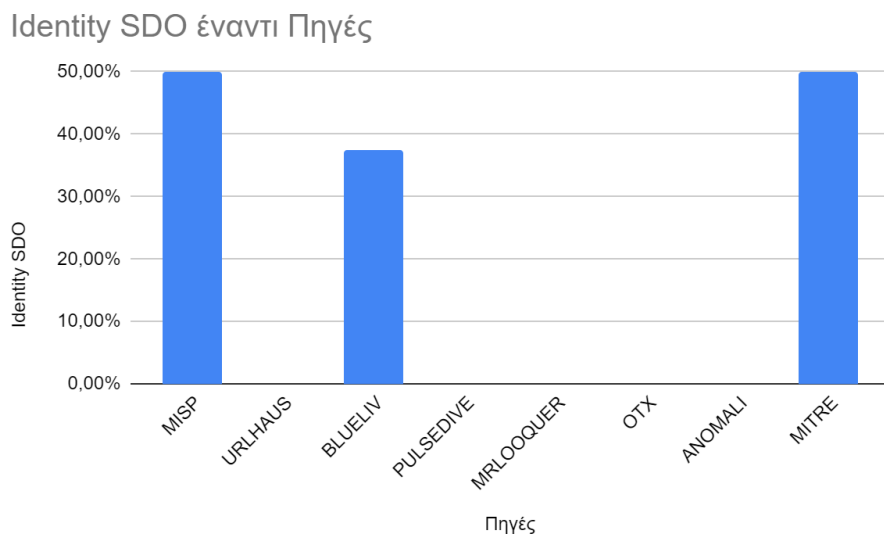
Γράφημα 11: Πληρότητα των πηγών για Malware SDO.

Το Indicator SDO χρησιμοποιείται για να περιγράψει μια ένδειξη ύποπτης ή κακόβουλης δραστηριότητας. Οι πηγές που προσφέρουν Indicator SDOs με μεγαλύτερη πληρότητα (ποσοστά μεγαλύτερα του 50%) σε αυξητική σειρά είναι οι: MISP, ANOMALI, PULSEDIVE, MRLOOQUER και OTX όπως φαίνεται στο Γράφημα 12.



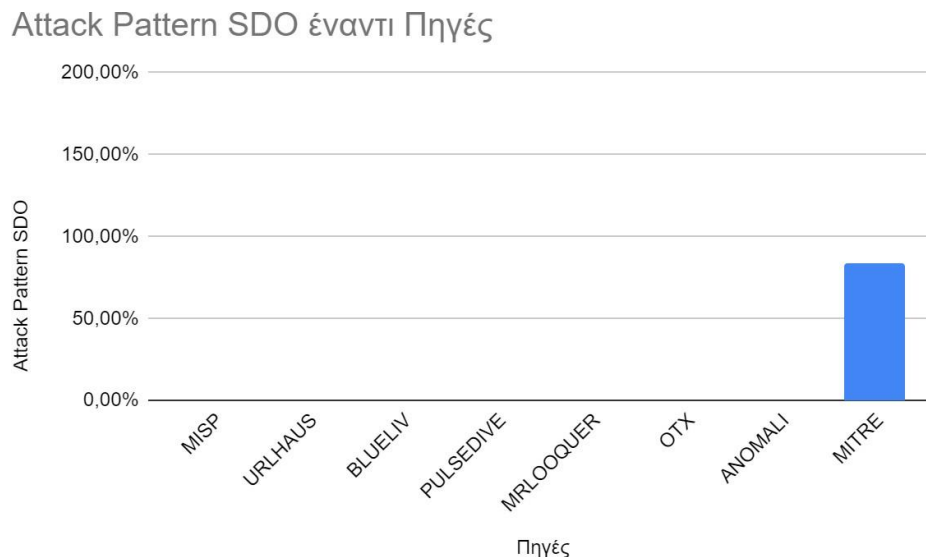
Γράφημα 12: Πληρότητα των πηγών για Indicator SDO.

Το Identity SDO περιγράφει άτομα, οργανισμούς ή ομάδες αυτών, καθώς και κλάσεις ατόμων, οργανισμών ή ομάδων. Όπως φαίνεται στο Γράφημα 13, η MITRE και η MISP προσφέρουν Identity SDOs με την υψηλότερη πληρότητα (τάξης του 50%) και ακολουθεί η BLUELIV με περίπου 40%.



Γράφημα 13: Πληρότητα των πηγών για Identity SDO.

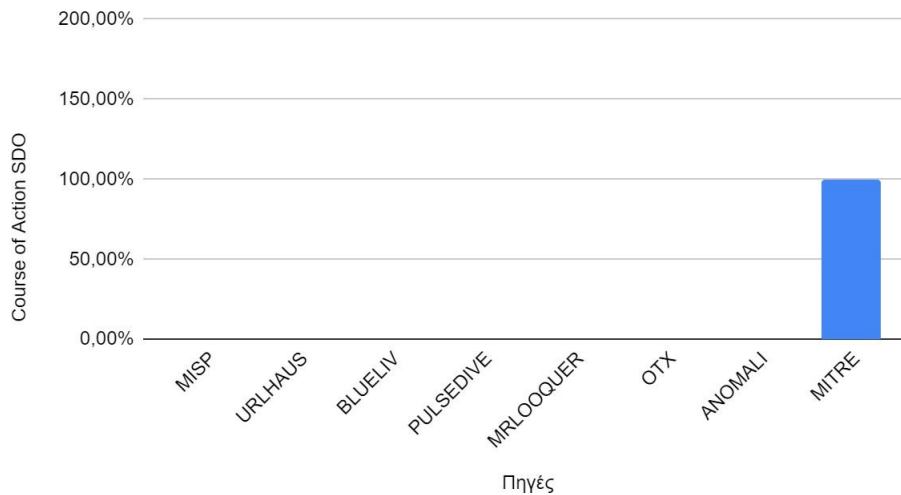
Το Attack Pattern SDO περιγράφει τρόπους με τους οποίους μπορεί να πραγματοποιηθεί μια επίθεση. Η μόνη πηγή που προσφέρει Attack Pattern SDO είναι η MITRE. Το εν λόγω SDO σημειώνει αρκετά μεγάλο ποσοστό πληρότητας της τάξης του 83% όπως παρατηρούμε στο Γράφημα 14.



Γράφημα 14: Πληρότητα των πηγών για Attack Pattern SDO.

Το Course of Action SDO είναι μια σειρά ενεργειών που συνίσταται να ληφθούν για την πρόληψη ή την αντιμετώπιση μιας επίθεσης. Η μόνη πηγή που προσφέρει Course of Action SDO είναι επίσης η MITRE. Το εν λόγω SDO σημειώνει το απόλυτο 100% πληρότητας των πεδίων όπως βλέπουμε και στο Γράφημα 15.

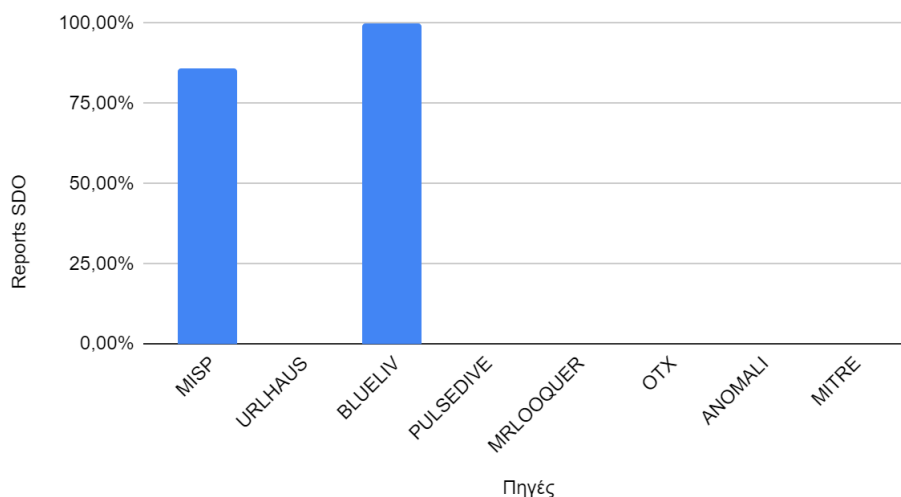
Course of Action SDO έναντι Πηγές



Γράφημα 15: Πληρότητα των πηγών για Course of Action SDO.

Το Report SDO αποτελεί την πλήρη περιγραφή μιας επίθεσης. Στην ουσία είναι το αποτέλεσμα μιας εγκληματολογικής ανάλυσης για το πως έλαβε χώρα μια επίθεση. Η BLUELIV και η MISP προσφέρουν Report SDOs με υψηλά ποσοστά πληρότητας. Η BLUELIV προσέφερε Report SDOs με πληρότητα 100% και τέλος η MISP προσφέρει εν τα εν λόγω SDO με πληρότητα 85% όπως μπορούμε να παρατηρήσουμε από το Γράφημα 16.

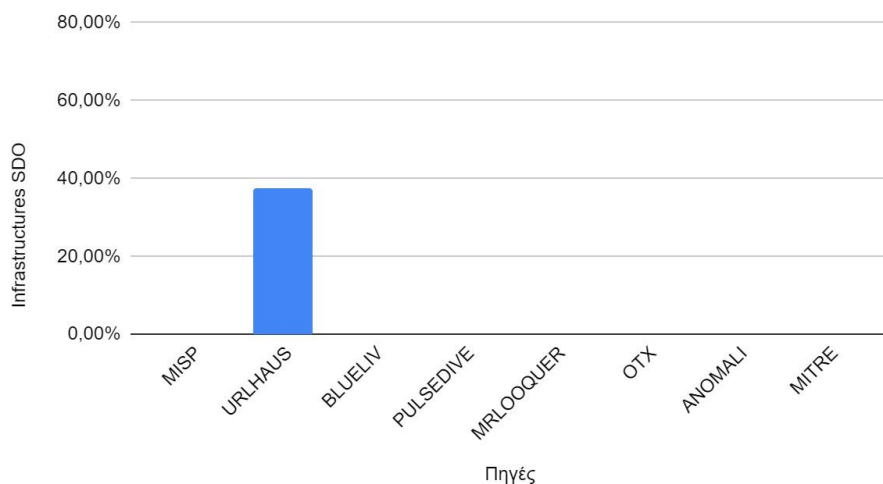
Reports SDO έναντι Πηγές



Γράφημα 16: Πληρότητα των πηγών για Report SDO.

Το Infrastructure SDO περιγράφει συστήματα, υπηρεσίες λογισμικού και συναφείς φυσικούς ή εικονικούς πόρους. Σε ότι αφορά την πληρότητα στο Infrastructure SDO, το αποθετήριο της URLHAUS είναι το μοναδικό που προσφέρει τέτοια SDOs και παρουσιάζει χαμηλή επίδοση της τάξης του 37,5% όπως βλέπουμε στο Γράφημα 17.

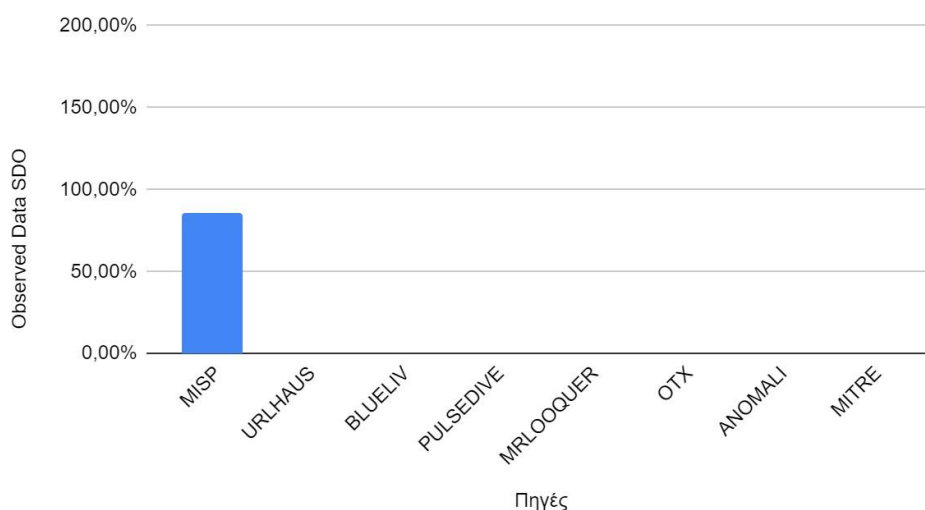
Infrastructures SDO έναντι Πηγές



Γράφημα 17: Πληρότητα των πηγών για Infrastructure SDO.

Το Observed Data SDO μεταφέρει πληροφορίες που παρατηρήθηκαν σε συστήματα και δίκτυα, όπως δεδομένα καταγραφής ή κυκλοφορία δικτύου. Η μόνη πηγή που προσφέρει Observed Data SDO είναι η MISP. Το εν λόγω SDO σημειώνει αρκετά μεγάλο ποσοστό πληρότητας της τάξης του 85,71% όπως παρατηρούμε και στο Γράφημα 18.

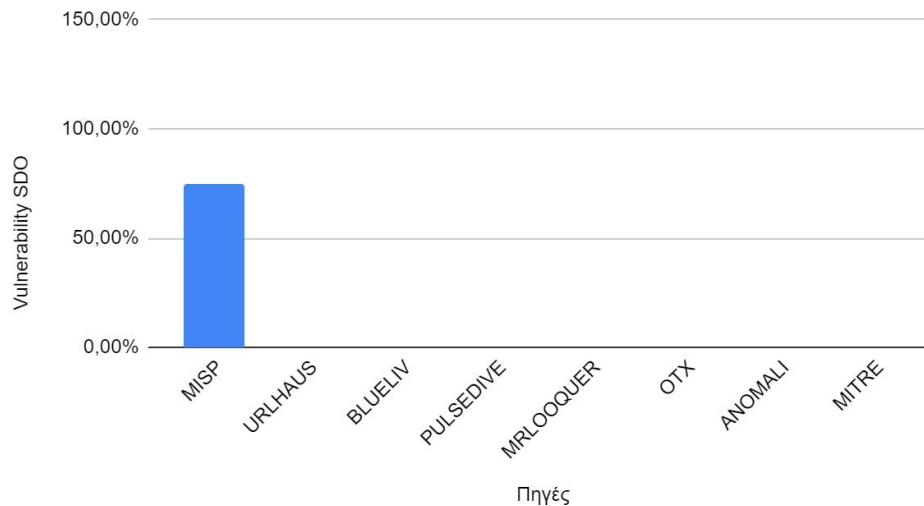
Observed Data SDO έναντι Πηγές



Γράφημα 18: Πληρότητα των πηγών για Observed Data SDO.

Το Vulnerability SDO περιγράφει μια αδυναμία σε ένα σύστημα, λογισμικό ή δίκτυο που μπορεί να εκμεταλλευτεί ένας επιτιθέμενος για να αποκτήσει πρόσβαση σε αυτό. Η μόνη πηγή που προσφέρει Vulnerability SDO είναι η MISP. Το εν λόγω SDO σημειώνει αρκετά μεγάλο ποσοστό πληρότητας της τάξης του 75%, όπως βλέπουμε και στο Γράφημα 19.

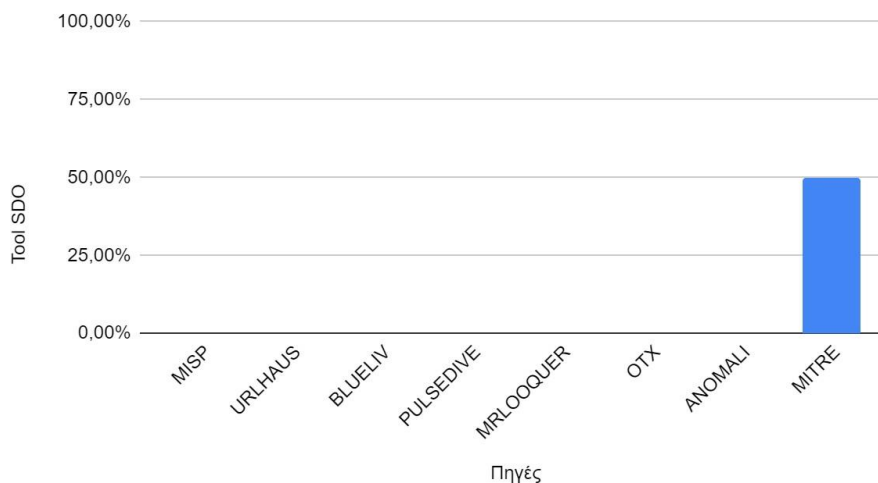
Vulnerability SDO έναντι Πηγές



Γράφημα 19: Πληρότητα των πηγών για Vulnerability SDO.

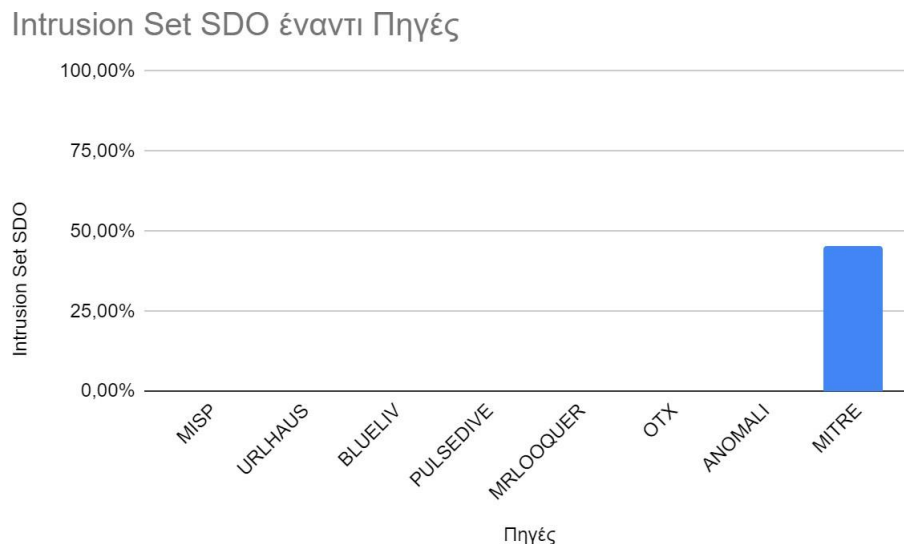
Το Tool SDO περιγράφει ένα νόμιμο λογισμικό που μπορεί να χρησιμοποιηθεί από επιτιθέμενους για την διεξαγωγή επιθέσεων. Η μόνη πηγή που προσφέρει Tool SDO είναι η MISP. Το εν λόγω SDO σημειώνει μέσο ποσοστό πληρότητας της τάξης του 50% όπως παρατηρούμε και στο Γράφημα 20.

Tool SDO έναντι Πηγές



Γράφημα 20: Πληρότητα των πηγών για Tool SDO.

Το Intrusion Set SDO περιγράφει το σύνολο των εργαλείων, τεχνικών και συμπεριφορών που χρησιμοποιούνται για την διεξαγωγή μιας επίθεσης. Η μόνη πηγή που προσφέρει Intrusion Set SDO είναι η MITRE. Το εν λόγω SDO σημειώνει μέσο ποσοστό πληρότητας της τάξης του 45% όπως βλέπουμε και στο Γράφημα 21.



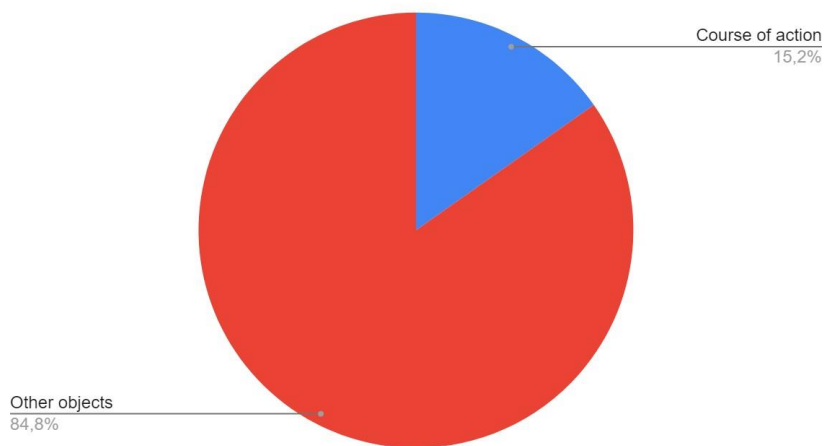
Γράφημα 21: Πληρότητα των πηγών για Intrusion Set SDO.

Συμπερασματικά, παρατηρούμε ότι η MITRE, η οποία παρέχει τα περισσότερα διαφορετικά SDOs, εμφανίζει ικανοποιητική πληρότητα στα Attack Pattern, Tool, Identity και Course of Action SDOs. Η MISP, η οποία επίσης παρέχει πολλά διαφορετικά SDOs, εμφανίζει υψηλά ποσοστά πληρότητας στα Indicator, Identity, Report, Observed Data και Vulnerability SDOs. Η BLUELIV προσφέρει μόνο Identity και Report SDOs με μεγάλη πληρότητα να εμφανίζουν τα Report SDOs. Η URLHAUS προσφέρει μόνο Infrastructure και Malware SDOs με χαμηλά ποσοστά πληρότητας. Η PULSEDIVE και OTX προσφέρουν Indicator και Malware SDOs με μεγάλη πληρότητα να εμφανίζουν στα Indicator SDOs. Η MRLOOQUER και ANOMALI προσφέρουν μόνο Indicator SDOs με υψηλό ποσοστό πληρότητας.

7.3. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΑ COA

Ακόμα ένα ποιοτικό κριτήριο που μπορεί να χρησιμοποιηθεί πρακτικά στην αξιολόγηση των πηγών είναι το αν παρέχονται πληροφορίες που μπορούν να χρησιμοποιηθούν για πρόληψη και την αντιμετώπιση απειλών. Σύμφωνα με το Γράφημα 22, καμία πηγή δεν προσφέρει CTIPs τύπου CoA SDOs εκτός από την MITRE. Στο αποθετήριο της MITRE περιέχονται 1955 τέτοιου τύπου CTIPs (15,24%).

MITRE - Course of action



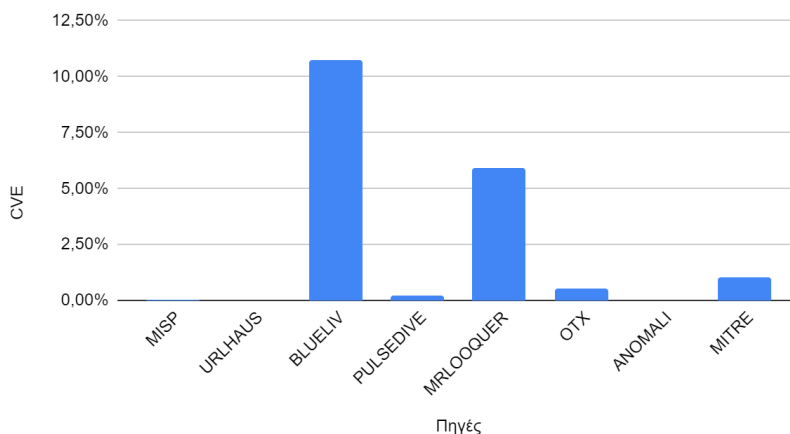
Γράφημα 22: CoA στα CTIPs της MITRE.

7.4. ΑΞΙΟΛΟΓΗΣΗ ΜΕ ΒΑΣΗ ΤΑ CVE, CPE, CAPEC

Άλλα κριτήρια για την αξιολόγηση μιας πηγής μπορούν να είναι το κατά πόσο περιέχονται στα CTIP της πληροφορίες για: CVE, CPE και CAPEC.

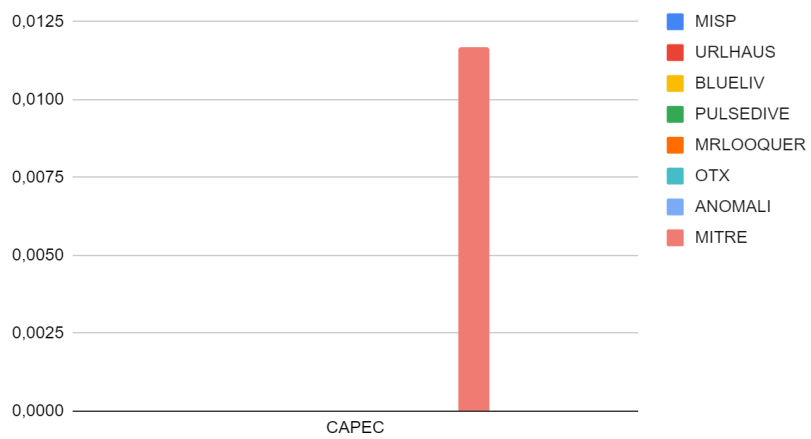
Παρατηρώντας το Γράφημα 23, βλέπουμε πως έξι πηγές προσφέρουν CTIPs που περιέχουν πληροφορίες σχετικά με CVEs. Επίσης παρατηρούμε ότι μία μόνο πηγή (MITRE) αναφέρει πληροφορίες για CAPECs. Η MISP προσέφερε 0,06% CTIPs που περιείχαν πληροφορίες για CVEs. Η MITRE 1,06%, η BLUELIV 10,76%, η PULSEDIVE 0,21%, η MRLOOQUER 5,94% και η OTX 0,54%. Η MITRE, παρατηρώντας και το Γράφημα 24, προσέφερε 1,17% CTIPs που περιείχαν πληροφορίες για CAPECs. Σημειώνεται ότι καμία πηγή δεν προσέφερε CTIPs που περιέχουν πληροφορίες για CPEs.

CVE έναντι Πηγές



Γράφημα 23: Παροχή αναφορών για CVE στις πηγές.

CAPEC έναντι Πηγές



Γράφημα 24: Παροχή αναφορών για CAPEC στις πηγές.

8. ΕΠΙΛΟΓΟΣ

Η παρούσα έρευνα επικεντρώθηκε στην αξιολόγηση ελεύθερα διαθέσιμων πηγών ως προς συγκεκριμένα κριτήρια και βάση των CTIPs που προσφέρουν. Απώτερος σκοπός είναι να παρέχει πληροφορίες για τα τωρινά προσφερόμενα CTIPs έτσι ώστε να αναδείξει περιοχές που χρήζουν βελτίωσης.

Τα αποτελέσματα της έρευνας έδειξαν πως στη πράξη, οι MITRE και MISP, οι πιο φημισμένες πηγές CTI, προσφέρουν τα περισσότερα διαφορετικά SDOs (περισσότερα από 4), με τις υπόλοιπες να προσφέρουν από ένα με τρία το πολύ, τα οποία συνήθως είναι Indicator και Malware SDOs. CTIPs που περιέχουν πληροφορίες για τα στάδια μιας επίθεσης στην βάση της KC προσφέρουν μόνο η MISP και η MITRE. Η πρώτη διαθέτει περισσότερα CTIPs με πεδία KC από την δεύτερη. Στην αξιολόγηση των CTIPs που προσφέρονται από τις υπό εξέταση πηγές, οι λιγότερο γνωστές όπως οι BLUELIV, URLHAUS, MRLOOQUER και OTX, περιέχουν τα πιο επίκαιρα CTIPs, καθώς τα μεγαλύτερα ποσοστά τους προέρχονται από ημερομηνίες καταχώρησης το 2021. Όσον αφορά την πληρότητα των CTIPs που προσφέρονται από τις πηγές, παρουσιάζεται το αντίθετο, καθώς οι περισσότεροι φημισμένες όπως η MITRE και η MISP, αποδεικνύουν πως έχουν περισσότερη πληρότητα στα CTIPs τους από τις λιγότερο γνωστές. Συνιστάμενες ενέργειες δράσης για την πρόληψη και αντιμετώπιση κυβερνοαπειλών (course of action) υπήρχαν μόνο σε CTIPs της πηγής MITRE. Πληροφορίες για γνωστές ευπάθειες (CVE) περιείχαν σχεδόν όλες οι πηγές με τις BLUELIV και MRLOOQUER να κατέχουν τα μεγαλύτερα ποσοστά. Πληροφορίες για γνωστές πλατφόρμες (CPE) δεν περιείχε καμία πηγή, και τέλος πληροφορίες για γνωστά μοτίβα επίθεσης (CAPEC) περιέχει μόνο η MITRE.

Συμπερασματικά λοιπόν, μπορούμε να αναφέρουμε πως στο τακτικό CTI που είναι περισσότερο τεχνικής φύσης και πιο άμεσο, μπορούν να χρησιμοποιηθούν περισσότερο οι πηγές μικρότερης αναγνωρισιμότητας, καθώς μέσω της εργασίας παρατηρείται μεγαλύτερη φρεσκάδα και μικρότερη πληρότητα στα CTIPs από τέτοιες πηγές. Οι περισσότεροι γνωστές πηγές, εφόσον αποδείχτηκε πως παρέχουν CTIPs από πολλές χρονικές περιόδους, μεγαλύτερη πληρότητα και περισσότερη πληροφορία για πρόληψη και μετριασμό των απειλών, μπορούν να χρησιμοποιηθούν στο επιχειρησιακό και στρατηγικό CTI, στα οποία χρειάζονται περισσότερη κατανόηση της απειλής για το πρώτο, και για το δεύτερο που χρειάζεται μια μεγαλύτερη εικόνα των απειλών σε βάθος χρόνου και αλλαγής τάσεων.

Μελλοντική έρευνα αφορά στις εφαρμογές του CTI και του προτύπου STIX σε προγράμματα εντοπισμού επιθέσεων (Intrusion Detection System), σύγκριση προτύπων για την αναπαράσταση κυβερνοαπειλών και αυτόματη δημιουργία CTIPs σε STIX μετά από μια επίθεση.

9. ΒΙΒΛΙΟΓΡΑΦΙΑ

- [1] "What is Indicators of Compromise (IOC)? - Definition from Whatis.com," *SearchSecurity*. [Online]. Available: <https://searchsecurity.techtarget.com/definition/Indicators-of-Compromise-IOC>. [Accessed: 19-May-2021]
- [2] "MITRE ATT&CK - Courses of Action | Cortex XSOAR." [Online]. Available: <https://xsoar.pan.dev/docs/reference/articles/courses-of-action>. [Accessed: 19-May-2021]
- [3] "What is a CVE?" [Online]. Available: <https://www.redhat.com/en/topics/security/what-is-cve>. [Accessed: 19-May-2021]
- [4] "CVE - CVE." [Online]. Available: <https://cve.mitre.org/>. [Accessed: 19-May-2021]
- [5] "NVD - Vulnerabilities." [Online]. Available: <https://nvd.nist.gov/vuln>. [Accessed: 03-Jun-2021]
- [6] "CVE - CVE-2021-29041." [Online]. Available: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-29041>. [Accessed: 03-Jun-2021]
- [7] I. T. L. Computer Security Division, "Common Platform Enumeration (CPE) - Security Content Automation Protocol | CSRC | CSRC," *CSRC | NIST*, 07-Dec-2016. [Online]. Available: <https://csrc.nist.gov/projects/security-content-automation-protocol/specifications/cpe>. [Accessed: 19-May-2021]
- [8] "National Institute of Standards and Technology," *NIST*. [Online]. Available: <https://www.nist.gov/>. [Accessed: 19-May-2021]
- [9] "CAPEC - About CAPEC." [Online]. Available: <https://capec.mitre.org/about/index.html>. [Accessed: 19-May-2021]
- [10] "CAPEC - Common Attack Pattern Enumeration and Classification (CAPEC™)." [Online]. Available: <https://capec.mitre.org/>. [Accessed: 19-May-2021]
- [11] "Common Attack Pattern Enumeration and Classification (CAPEC)." [Online]. Available: <https://samate.nist.gov/BF/Enlightenment/CAPEC.html>. [Accessed: 03-Jun-2021]
- [12] "CWE - Common Weakness Enumeration." [Online]. Available: <https://cwe.mitre.org/>. [Accessed: 03-Jun-2021]
- [13] C. C. Editor, "Tactics, Techniques, and Procedures (TTPs) - Glossary | CSRC." [Online]. Available: https://csrc.nist.gov/glossary/term/Tactics_Techniques_and_Procedures. [Accessed: 19-May-2021]
- [14] M. K. and L. Myers, "What is the cyber kill chain? Why it's not always the right approach to cyber attacks," *CSO Online*, 15-Nov-2018. [Online]. Available: <https://www.csoonline.com/article/2134037/strategic-planning-erm-the-practicality-of-the-cyber-kill-chain-approach-to-security.html>. [Accessed: 19-May-2021]
- [15] "Cyber Kill Chain® | Lockheed Martin." [Online]. Available: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>. [Accessed: 19-May-2021]
- [16] "CVE - CVE-2021-28356." [Online]. Available: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-28356>. [Accessed: 19-May-2021]
- [17] "What is MITRE ATT&CK: An Explainer | Exabeam." [Online]. Available: <https://www.exabeam.com/information-security/what-is-mitre-attck-an-explainer/>. [Accessed: 19-May-2021]
- [18] "CyCraft Classroom: MITRE ATT&CK vs. Cyber Kill Chain vs. Diamond Model | by CyCraft Technology Corp | CyCraft | Medium." [Online]. Available: <https://medium.com/cycraft/cycraft-classroom-mitre-att-ck-vs-cyber-kill-chain-vs-diamond-model-1cc8fa49a20f>. [Accessed: 19-May-2021]
- [19] "Putting Your TAXII Server to Work." [Online]. Available: <https://www.anomali.com/blog/putting-your-taxii-server-to-work>. [Accessed: 19-May-2021]
- [20] "taxii2-client · PyPI." [Online]. Available: <https://pypi.org/project/taxii2-client/>.

- [Accessed: 19-May-2021]
- [21] K. Rantos, A. Spyros, A. Papanikolaou, A. Kritsas, C. Ilioudis, and V. Katos, "Interoperability Challenges in the Cybersecurity information Sharing Ecosystem," *Computers*, vol. 9, no. 1, p. 18, Mar. 2020, doi: 10.3390/computers9010018. [Online]. Available: <https://www.mdpi.com/2073-431X/9/1/18>. [Accessed: 19-May-2021]
 - [22] C. Johnson, M. Badger, D. Waltermire, J. Snyder, and C. Skorupka, "Guide to Cyber Threat information Sharing," National Institute of Standards and Technology, NIST Special Publication (SP) 800-150, Oct. 2016 [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-150/final>. [Accessed: 19-May-2021]
 - [23] "introduction to CTI as a General topic / Cyber Threat intelligence SIG Curriculum," *FIRST — Forum of Incident Response and Security Teams*. [Online]. Available: <https://www.first.org/global/sigs/cti/curriculum/cti-introduction>. [Accessed: 19-May-2021]
 - [24] "Introduction to STIX." [Online]. Available: <https://oasis-open.github.io/cti-documentation/stix/intro>. [Accessed: 31-May-2021]
 - [25] "EUR-Lex - 32017D2288 - EN - EUR-Lex." [Online]. Available: <https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=CELEX%3A32017D2288>. [Accessed: 19-May-2021]
 - [26] "Indicator for Malicious URL." [Online]. Available: <https://oasis-open.github.io/cti-documentation/examples/indicator-for-malicious-url>. [Accessed: 19-May-2021]
 - [27] "STIX™ Version 2.1." [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/csprd01/stix-v2.1-csprd01.html>. [Accessed: 19-May-2021]
 - [28] "The Ultimate Guide to Cyber Threat intelligence (CTI) in 2021," 09-Apr-2020. [Online]. Available: <https://research.aimultiple.com/cti/>. [Accessed: 19-May-2021]
 - [29] H. Griffioen, T. Booi, and C. Doerr, "Quality Evaluation of Cyber Threat intelligence Feeds," 2020, pp. 277-296.
 - [30] "oasis-open/cti-stix2-json-schemas," *GitHub*. [Online]. Available: <https://github.com/oasis-open/cti-stix2-json-schemas>. [Accessed: 19-May-2021]
 - [31] "SQL vs NoSQL: What's the Difference Between SQL and NoSQL." [Online]. Available: <https://www.guru99.com/sql-vs-nosql.html>. [Accessed: 19-May-2021]
 - [32] "Advantages of NoSQL," *MongoDB*. [Online]. Available: <https://www.mongodb.com/nosql-explained/advantages>. [Accessed: 19-May-2021]
 - [33] "Graph Database Platform | Graph Database Management System | Neo4j," *Neo4j Graph Database Platform*. [Online]. Available: <https://neo4j.com/>. [Accessed: 19-May-2021]
 - [34] "The most popular database for modern apps," *MongoDB*. [Online]. Available: <https://www.mongodb.com>. [Accessed: 19-May-2021]
 - [35] "MISP - Open Source Threat Intelligence Platform & Open Standards For Threat Information Sharing (formerly known as Malware information Sharing Platform)." [Online]. Available: <https://www.misp-project.org/>. [Accessed: 19-May-2021]
 - [36] "Limo - Free intel Feed." [Online]. Available: <https://www.anomali.com/resources/limo>. [Accessed: 19-May-2021]
 - [37] "MITRE ATT&CK®." [Online]. Available: <https://attack.mitre.org/>. [Accessed: 19-May-2021]
 - [38] "Threat exchange network - Blueliv community." [Online]. Available: <https://community.blueliv.com/#!/discover>. [Accessed: 19-May-2021]
 - [39] "AlienVault - Open Threat Exchange," *AlienVault Open Threat Exchange*. [Online]. Available: <https://otx.alienvault.com/dashboard/new>. [Accessed: 19-May-2021]
 - [40] "URLhaus | Malware URL exchange." [Online]. Available: <https://urlhaus.abuse.ch/>. [Accessed: 19-May-2021]
 - [41] P. LLC, "Threat intelligence - Pulsedive." [Online]. Available: <https://pulsedive.com/>. [Accessed: 19-May-2021]
 - [42] "Mr Looquer," *Mr Looquer*. [Online]. Available: <https://www.mrllooquer.com>. [Accessed: 19-May-2021]
 - [43] "Requests: HTTP for Humans™ – Requests 2.25.1 documentation." [Online]. Available: <https://docs.python-requests.org/en/master/>. [Accessed: 03-Jun-2021]

- [44] *oasis-open/cti-python-stix2*. OASIS TC Open Repositories, 2021 [Online]. Available: <https://github.com/oasis-open/cti-python-stix2>. [Accessed: 03-Jun-2021]